

	DIN EN IEC 62443-4-1 (VDE 0802-4-1)	DIN
	Diese Norm ist zugleich eine VDE-Bestimmung im Sinne von VDE 0022. Sie ist nach Durchführung des vom VDE-Präsidium beschlossenen Genehmigungsverfahrens unter der oben angeführten Nummer in das VDE-Vorschriftenwerk aufgenommen und in der „etz Elektrotechnik + Automation“ bekannt gegeben worden.	VDE
Vervielfältigung – auch für innerbetriebliche Zwecke – nicht gestattet. ICS 25.040.40; 35.030; 35.240.50 IT-Sicherheit für industrielle Automatisierungssysteme – Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung (IEC 62443-4-1:2018); Deutsche Fassung EN IEC 62443-4-1:2018 Security for industrial automation and control systems – Part 4-1: Secure product development lifecycle requirements (IEC 62443-4-1:2018); German version EN IEC 62443-4-1:2018 Sécurité des automatismes industriels et des systèmes de commande – Partie 4-1: Exigences applicables au cycle de vie de développement sécurisé des produits (IEC 62443-4-1:2018); Version allemande EN IEC 62443-4-1:2018 Gesamtumfang 63 Seiten DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE		

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10**Anwendungsbeginn**

Anwendungsbeginn für die von CENELEC am 2018-02-19 angenommene Europäische Norm als DIN-Norm ist 2018-10-01.

Nationales Vorwort

Vorausgegangener Norm-Entwurf: E DIN EN 62443-4-1 (VDE 0802-4-1):2016-11.

Für dieses Dokument ist das nationale Arbeitsgremium UK 931.1 „IT-Sicherheit in der Automatisierungstechnik“ der DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE (www.dke.de) zuständig.

Die enthaltene IEC-Publikation wurde vom TC 65 „Industrial-process measurement and control“ erarbeitet.

Das IEC-Komitee hat entschieden, dass der Inhalt dieser Publikation bis zu dem Datum (stability date) unverändert bleiben soll, das auf der IEC-Website unter „http://webstore.iec.ch“ zu dieser Publikation angegeben ist. Zu diesem Zeitpunkt wird entsprechend der Entscheidung des Komitees die Publikation

- bestätigt,
- zurückgezogen,
- durch eine Folgeausgabe ersetzt oder
- geändert.

Das Original-Dokument enthält Bilder in Farbe, die in der Papierversion in einer Graustufen-Darstellung wiedergegeben werden. Elektronische Versionen dieses Dokuments enthalten die Bilder in der originalen Farbdarstellung.

Nationaler Anhang NA (informativ)

Zusammenhang mit europäischen und internationalen Dokumenten

Für den Fall einer undatierten Verweisung im normativen Text (Verweisung auf ein Dokument ohne Angabe des Ausgabedatums und ohne Hinweis auf eine Abschnittsnummer, eine Tabelle, ein Bild usw.) bezieht sich die Verweisung auf die jeweils aktuellste Ausgabe des in Bezug genommenen Dokuments.

Für den Fall einer datierten Verweisung im normativen Text bezieht sich die Verweisung immer auf die in Bezug genommene Ausgabe des Dokuments.

Eine Information über den Zusammenhang der zitierten Dokumente mit den entsprechenden deutschen Dokumenten ist nachstehend wiedergegeben.

Tabelle NA.1 (1 von 2)

Europäisches Dokument	Internationales Dokument	Deutsches Dokument	Klassifikation im VDE-Vorschriftenwerk
EN 61508 (alle Teile)	IEC 61508 (alle Teile)	DIN EN 61508 (VDE 0803) (alle Teile)	VDE 0803
EN 62443 (alle Teile)	IEC 62443 (alle Teile)	DIN EN 62443 (VDE 0802) (alle Teile)	VDE 0802

Tabelle NA.1 (2 von 2)

Europäisches Dokument	Internationales Dokument	Deutsches Dokument	Klassifikation im VDE-Vorschriftenwerk
–	IEC 62443-2-1	–	–
–	IEC 62443-2-4:2015 + Cor.:2015	DIN IEC 62443-2-4 (VDE 0802-2-4) ^a	VDE 0802-2-4
–	IEC 62443-3-2 ^a	–	–
–	IEC 62443-3-3	DIN IEC 62443-3-3 (VDE 0802-3-3) ^a	VDE 0802-3-3
EN 62443-4-2 ^a	IEC 62443-4-2 ^a	DIN EN 62443-4-2 (VDE 0802-4-2) ^a	VDE 0802-4-2
EN 62740	IEC 62740	DIN EN 62740	–
–	IEC/TS 62443-1-1	–	–
–	IEC/TR 62443-1-2 ^a	–	–
–	IEC/TS 62443-1-3 ^a	–	–
–	IEC/TR 62443-1-4 ^a	–	–
–	IEC/TR 62443-2-2 ^a	–	–
–	IEC/TR 62443-2-3	–	–
–	IEC/TR 62443-3-1:2009	–	–
EN ISO 9001	ISO 9001	DIN EN ISO 9001	–
–	ISO/IEC 10746-1	–	–
–	ISO/IEC 10746-2	–	–
–	ISO/IEC 15408-1	–	–
–	ISO/IEC 15408-2	–	–
–	ISO/IEC 15408-3	–	–
EN ISO/IEC 27001	ISO/IEC 27001	DIN EN ISO/IEC 27001	–
EN ISO/IEC 27002	ISO/IEC 27002	DIN EN ISO/IEC 27002	–
–	ISO/IEC 27034 (alle Teile)	–	–
–	ISO/IEC 27036-3	–	–
–	ISO/IEC 29147	–	–
–	ISO/IEC 30111	–	–
^a In Vorbereitung.			

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10

Nationaler Anhang NB (informativ)

Literaturhinweise

DIN EN 61508 (VDE 0803) (alle Teile), *Funktionale Sicherheit sicherheitsbezogener elektrischer/elektronischer/programmierbarer elektronischer Systeme*

DIN EN 62443 (VDE 0802) (alle Teile), *IT-Sicherheit für industrielle Automatisierungssysteme*

DIN EN 62443-4-2 (VDE 0802-4-2) (in Vorbereitung), *Industrielle Kommunikationsnetze – IT-Sicherheit für industrielle Automatisierungssysteme – Teil 4-2: Anforderungen an Komponenten industrieller Automatisierungssysteme*

DIN EN 62740, *Grundursachenanalyse*

DIN EN ISO 9001, *Qualitätsmanagementsysteme – Anforderungen*

DIN EN ISO/IEC 27001, *Informationstechnik – Sicherheitsverfahren – Informationssicherheitsmanagementsysteme – Anforderungen*

DIN EN ISO/IEC 27002, *Informationstechnik – Sicherheitsverfahren – Leitfaden für Informationssicherheitsmaßnahmen*

DIN IEC 62443-2-4 (VDE 0802-2-4) (in Vorbereitung), *IT-Sicherheit für industrielle Automatisierungssysteme – Teil 2-4: Anforderungen an das IT-Sicherheitsprogramm von Dienstleistern für industrielle Automatisierungssysteme (IEC 62443-2-4:2015 + Cor.:2015), mit CD-ROM*

DIN IEC 62443-3-3 (VDE 0802-3-3) (in Vorbereitung), *Industrielle Kommunikationsnetze – IT-Sicherheit für Netze und Systeme – Teil 3-3: Systemanforderungen zur IT-Sicherheit und Security-Level*

EUROPÄISCHE NORM
EUROPEAN STANDARD
NORME EUROPÉENNE

EN IEC 62443-4-1

März 2018

ICS 35.030; 25.040.40

Deutsche Fassung

**IT-Sicherheit für industrielle Automatisierungssysteme –
Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere
Produktentwicklung**
(IEC 62443-4-1:2018)

Security for industrial automation and control
systems –
Part 4-1: Secure product development lifecycle
requirements
(IEC 62443-4-1:2018)

Sécurité des automatismes industriels et des
systèmes de commande –
Partie 4-1: Exigences applicables au cycle de
vie de développement sécurisé des produits
(IEC 62443-4-1:2018)

Diese Europäische Norm wurde von CENELEC am 2018-02-19 angenommen. CENELEC-Mitglieder sind gehalten, die CEN/CENELEC-Geschäftsordnung zu erfüllen, in der die Bedingungen festgelegt sind, unter denen dieser Europäischen Norm ohne jede Änderung der Status einer nationalen Norm zu geben ist.

Auf dem letzten Stand befindliche Listen dieser nationalen Normen mit ihren bibliographischen Angaben sind beim CEN-CENELEC Management Centre oder bei jedem CENELEC-Mitglied auf Anfrage erhältlich.

Diese Europäische Norm besteht in drei offiziellen Fassungen (Deutsch, Englisch, Französisch). Eine Fassung in einer anderen Sprache, die von einem CENELEC-Mitglied in eigener Verantwortung durch Übersetzung in seine Landessprache gemacht und dem CEN-CENELEC Management Centre mitgeteilt worden ist, hat den gleichen Status wie die offiziellen Fassungen.

CENELEC-Mitglieder sind die nationalen elektrotechnischen Komitees von Belgien, Bulgarien, Dänemark, Deutschland, der ehemaligen jugoslawischen Republik Mazedonien, Estland, Finnland, Frankreich, Griechenland, Irland, Island, Italien, Kroatien, Lettland, Litauen, Luxemburg, Malta, den Niederlanden, Norwegen, Österreich, Polen, Portugal, Rumänien, Schweden, der Schweiz, Serbien, der Slowakei, Slowenien, Spanien, der Tschechischen Republik, der Türkei, Ungarn, dem Vereinigten Königreich und Zypern.



Europäisches Komitee für Elektrotechnische Normung
European Committee for Electrotechnical Standardization
Comité Européen de Normalisation Electrotechnique

CEN-CENELEC Management Centre: Rue de la Science 23, B-1040 Brüssel

© 2018 CENELEC – Alle Rechte der Verwertung, gleich in welcher Form und in welchem Verfahren, sind weltweit den Mitgliedern von CENELEC vorbehalten.

Ref. Nr. EN IEC 62443-4-1:2018 D

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10
EN IEC 62443-4-1:2018

Europäisches Vorwort

Der Text des Dokuments 65/685/FDIS, zukünftige 1. Ausgabe der IEC 62443-4-1, erarbeitet vom IEC/TC 65 „Industrial-process measurement, control and automation“, wurde zur parallelen IEC-CENELEC-Abstimmung vorgelegt und von CENELEC als EN IEC 62443-4-1:2018 angenommen.

Nachstehende Daten wurden festgelegt:

- spätestes Datum, zu dem dieses Dokument auf nationaler Ebene durch Veröffentlichung einer identischen nationalen Norm oder durch Anerkennung übernommen werden muss (dop): 2018-11-19
- spätestes Datum, zu dem nationale Normen, die diesem Dokument entgegenstehen, zurückgezogen werden müssen (dow): 2021-02-19

Es wird auf die Möglichkeit hingewiesen, dass einige Elemente dieses Dokuments Patentrechte berühren können. CENELEC ist nicht dafür verantwortlich, einige oder alle diesbezüglichen Patentrechte zu identifizieren.

Anerkennungsnotiz

Der Text der Internationalen Norm IEC 62443-4-1:2018 wurde von CENELEC ohne irgendeine Abänderung als Europäische Norm angenommen.

In der offiziellen Fassung sind unter „Literaturhinweise“ zu den aufgelisteten Normen die nachstehenden Anmerkungen einzutragen:

IEC 62740	ANMERKUNG	Harmonisiert als EN 62470.
IEC 61508 (Reihe)	ANMERKUNG	Harmonisiert in der Reihe EN 61508.
ISO/IEC 27001	ANMERKUNG	Harmonisiert als EN ISO/IEC 27001.
ISO/IEC 27002	ANMERKUNG	Harmonisiert als EN ISO/IEC 27002.
ISO 9001	ANMERKUNG	Harmonisiert als EN ISO 9001.

Inhalt		Seite
Europäisches Vorwort		2
Einleitung		8
1	Anwendungsbereich	11
2	Normative Verweisungen	11
3	Begriffe, Abkürzungen, Akronyme und Vereinbarungen	11
3.1	Begriffe	11
3.2	Abkürzungen und Akronyme	18
3.3	Vereinbarungen	18
4	Allgemeine Grundsätze	19
4.1	Ziele	19
4.2	Reifegradmodell	20
5	Ansatz 1 – Verwaltung der IT-Sicherheit	22
5.1	Zweck	22
5.2	SM-1: Entwicklungsprozess	22
5.2.1	Anforderung	22
5.3	Begründung und zusätzliche Leitfäden	22
5.4	SM-2: Kennzeichnung von Verantwortlichkeiten	23
5.4.1	Anforderung	23
5.4.2	Begründung und zusätzliche Leitfäden	23
5.5	SM-3: Kennzeichnung der Anwendbarkeit	23
5.5.1	Anforderung	23
5.5.2	Begründung und zusätzliche Leitfäden	23
5.6	SM-4: Fachkenntnisse im Hinblick auf die IT-Sicherheit	24
5.6.1	Anforderung	24
5.6.2	Begründung und zusätzliche Leitfäden	24
5.7	SM-5: Prozesseingrenzung	24
5.7.1	Anforderung	24
5.7.2	Begründung und zusätzliche Leitfäden	24
5.8	SM-6: Integrität von Dateien	24
5.8.1	Anforderung	24
5.8.2	Begründung und zusätzliche Leitfäden	25
5.9	SM-7: IT-Sicherheit der Entwicklungsumgebung	25
5.9.1	Anforderung	25
5.9.2	Begründung und zusätzliche Leitfäden	25
5.10	SM-8: Überwachung privater Schlüssel	25
5.10.1	Anforderung	25
5.10.2	Begründung und zusätzliche Leitfäden	25

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10
EN IEC 62443-4-1:2018

	Seite
5.11 SM-9: Anforderungen an die IT-Sicherheit von extern bereitgestellten Komponenten.....	25
5.11.1 Anforderung.....	25
5.11.2 Begründung und zusätzliche Leitfäden	26
5.12 SM-10: Kundenspezifische Komponenten von Fremdanbietern.....	26
5.12.1 Anforderung.....	26
5.12.2 Begründung und zusätzliche Leitfäden	26
5.13 SM-11: Bewertung und Behandlung sicherheitsbezogener Probleme	27
5.13.1 Anforderung.....	27
5.13.2 Begründung und zusätzliche Leitfäden	27
5.14 SM-12: Prozessverifikation.....	27
5.14.1 Anforderung.....	27
5.14.2 Begründung und zusätzliche Leitfäden	27
5.15 SM-13: Ständige Verbesserung	27
5.15.1 Anforderung.....	27
5.15.2 Begründung und zusätzliche Leitfäden	27
6 Ansatz 2 – Spezifikation der IT-Sicherheitsanforderungen	29
6.1 Zweck	29
6.2 SR-1: IT-Sicherheitsumfeld des Produkts	29
6.2.1 Anforderung.....	29
6.2.2 Begründung und zusätzliche Leitfäden	29
6.3 SR-2: Bedrohungsmodell	30
6.3.1 Anforderung.....	30
6.3.2 Begründung und zusätzliche Leitfäden	30
6.4 SR-3: IT-Sicherheitsanforderungen für das Produkt.....	31
6.4.1 Anforderung.....	31
6.4.2 Begründung und zusätzliche Leitfäden	31
6.5 SR-4: Anforderungen an das IT-Sicherheitsumfeld des Produkts	31
6.5.1 Anforderung.....	31
6.5.2 Begründung und zusätzliche Leitfäden	31
6.6 SR-5: Überblick über IT-Sicherheitsanforderungen	32
6.6.1 Anforderung.....	32
6.6.2 Begründung und zusätzliche Leitfäden	32
7 Ansatz 3 – IT-Sicherheit durch den Entwurf.....	32
7.1 Zweck	32
7.2 SD-1: Grundsätze für einen gesicherten Entwurf.....	32
7.2.1 Anforderung.....	32
7.2.2 Begründung und zusätzliche Leitfäden	33
7.3 SD-2: Entwurf eines Defense-in-Depth-Konzepts.....	34
7.3.1 Anforderung.....	34

	Seite
7.3.2 Begründung und zusätzliche Leitfäden	34
7.4 SD-3: Entwurfsprüfung der IT-Sicherheit	34
7.4.1 Anforderung	34
7.4.2 Begründung und zusätzliche Leitfäden	35
7.5 SD-4: Bewährte Verfahren des gesicherten Entwurfs	35
7.5.1 Anforderung	35
7.5.2 Begründung und zusätzliche Leitfäden	35
8 Ansatz 4 – Gesicherte Implementierung	36
8.1 Zweck	36
8.2 Anwendbarkeit	36
8.3 SI-1: Überprüfung der gesicherten Implementierung	36
8.3.1 Anforderung	36
8.3.2 Begründung und zusätzliche Leitfäden	36
8.4 SI-2: Codierungsnormen für IT-Sicherheit	37
8.4.1 Anforderung	37
8.4.2 Begründung und zusätzliche Leitfäden	37
9 Ansatz 5 – Verifikations- und Validierungsprüfungen der IT-Sicherheit	37
9.1 Zweck	37
9.2 SVV-1: Prüfung der IT-Sicherheitsanforderungen	38
9.2.1 Anforderung	38
9.2.2 Begründung und zusätzliche Leitfäden	38
9.3 SVV-2: Prüfung der Bedrohungsabschwächung	38
9.3.1 Anforderung	38
9.3.2 Begründung und zusätzliche Leitfäden	38
9.4 SVV-3: Prüfung von Sicherheitslücken	39
9.4.1 Anforderung	39
9.4.2 Begründung und zusätzliche Leitfäden	39
9.5 SVV-4: Eindringprüfung	39
9.5.1 Anforderung	39
9.5.2 Begründung und zusätzliche Leitfäden	39
9.6 SVV-5: Unabhängigkeit der Prüfer	40
9.6.1 Anforderung	40
9.6.2 Begründung und zusätzliche Leitfäden	41
10 Ansatz 6 – Behandlung sicherheitsbezogener Probleme	41
10.1 Zweck	41
10.2 DM-1: Empfang von Meldungen über sicherheitsbezogene Probleme	41
10.2.1 Anforderung	41
10.2.2 Begründung und zusätzliche Leitfäden	41
10.3 DM-2: Überprüfung sicherheitsbezogener Probleme	42

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10
EN IEC 62443-4-1:2018

	Seite
10.3.1 Anforderung.....	42
10.3.2 Begründung und zusätzliche Leitfäden	42
10.4 DM-3: Bewertung sicherheitsbezogener Probleme.....	42
10.4.1 Anforderung.....	42
10.4.2 Begründung und zusätzliche Leitfäden	43
10.5 DM-4: Behandlung sicherheitsbezogener Probleme.....	43
10.5.1 Anforderung.....	43
10.5.2 Begründung und zusätzliche Leitfäden	44
10.6 DM-5: Offenlegung sicherheitsbezogener Probleme	44
10.6.1 Anforderung.....	44
10.6.2 Begründung und zusätzliche Leitfäden	45
10.7 DM-6: Periodische Überprüfung der Behandlungsverfahren für Mängel der IT-Sicherheit	45
10.7.1 Anforderung.....	45
10.7.2 Begründung und zusätzliche Leitfäden	45
11 Ansatz 7 – Verwaltung von IT-Sicherheits-Updates.....	45
11.1 Zweck	45
11.2 SUM-1: Eignung von IT-Sicherheits-Updates	46
11.2.1 Anforderung.....	46
11.2.2 Begründung und zusätzliche Leitfäden	46
11.3 SUM-2: Dokumentation von IT-Sicherheits-Updates	46
11.3.1 Anforderung.....	46
11.3.2 Begründung und zusätzliche Leitfäden	46
11.4 SUM-3: Dokumentation der IT-Sicherheits-Updates für abhängige Komponenten oder Betriebssysteme	47
11.4.1 Anforderung.....	47
11.4.2 Begründung und zusätzliche Leitfäden	47
11.5 SUM-4: Auslieferung von IT-Sicherheits-Updates	47
11.5.1 Anforderung.....	47
11.5.2 Begründung und zusätzliche Leitfäden	47
11.6 SUM-5: Rechtzeitige Auslieferung von IT-Sicherheitspatches.....	47
11.6.1 Anforderung.....	47
11.6.2 Begründung und zusätzliche Leitfäden	48
12 Ansatz 8 – IT-Sicherheitsrichtlinien	48
12.1 Zweck	48
12.2 SG-1: Defense-in-Depth-Strategie für das Produkt.....	48
12.2.1 Anforderung.....	48
12.2.2 Begründung und zusätzliche Leitfäden	48
12.3 SG-2: Maßnahmen des Defense-in-Depth-Konzepts, die von der Umgebung zu erwarten sind	49

	Seite
12.3.1 Anforderung	49
12.3.2 Begründung und zusätzliche Leitfäden.....	49
12.4 SG-3: Richtlinien für die Härtung der IT-Sicherheit.....	49
12.4.1 Anforderung	49
12.4.2 Begründung und zusätzliche Leitfäden.....	50
12.5 SG-4: Richtlinien für eine gesicherte Entsorgung	50
12.5.1 Anforderung	50
12.5.2 Begründung und zusätzliche Leitfäden.....	50
12.6 SG-5: Richtlinien für einen gesicherten Betrieb	50
12.6.1 Anforderung	50
12.6.2 Begründung und zusätzliche Leitfäden.....	50
12.7 SG-6: Richtlinien für die Nutzerkontoverwaltung	51
12.7.1 Anforderung	51
12.7.2 Begründung und zusätzliche Leitfäden.....	51
12.8 SG-7: Überprüfung der Dokumentation	51
12.8.1 Anforderung	51
12.8.2 Begründung und zusätzliche Leitfäden.....	51
Anhang A (informativ) Mögliche Maßgrößen.....	52
Anhang B (informativ) Tabelle der Anforderungen.....	54
Literaturhinweise	56
Anhang ZA (normativ) Normative Verweisungen auf internationale Publikationen mit ihren entsprechenden europäischen Publikationen	59
 Bilder	
Bild 1 – Teile der Normenreihe IEC 62443.....	9
Bild 2 – Beispiel für den Anwendungsbereich eines Produktlebenszyklus	10
Bild 3 – Eine Defense-in-Depth-Strategie ist ein Kerngedanke des gesicherten Produktlebenszyklus.....	20
 Tabellen	
Tabelle 1 – Reifegrade	21
Tabelle 2 – Beispiele für Aktivitäten der ständigen Verbesserung von SDL	28
Tabelle 3 – Geforderter Grad der Unabhängigkeit der Prüfer von den Entwicklern	40
Tabelle B.1 – Zusammenfassung aller Anforderungen	54

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

Einleitung

Das vorliegende Dokument ist Teil einer Normenreihe, die sich mit der IT-Sicherheit für industrielle Automatisierungssysteme (IACS) befasst. Es beschreibt die Anforderungen an den Entwicklungslebenszyklus für Produkte in Bezug auf die IT-Sicherheit der Produkte, die für einen Einsatz in der Umgebung industrieller Automatisierungssysteme vorgesehen sind, und enthält einen Leitfaden für die Einhaltung der für jedes Element beschriebenen Anforderungen.

Dieses Dokument wurde in großen Teilen nach „Secure Development Life-cycle Assessment (SDLA) – Certification Requirements“ [\[26\]](#)¹ erarbeitet, welches vom ISA Security Compliance Institute (ISCI) entwickelt wurde. Dabei ist zu beachten, dass das SDLA-Verfahren auf folgende Quellen gestützt wurde:

- ISO/IEC 15408-3 (Common Criteria) [\[18\]](#);
- Open Web Application Security Project (OWASP) Comprehensive, Lightweight Application Security Process (CLASP) [\[36\]](#);
- The Security Development Life-cycle by Michael Howard and Steve Lipner [\[43\]](#);
- IEC 61508 Functional safety of electrical/electronic/ programmable electronic safety-related systems [\[24\]](#), und
- RCTA DO-178B Software Considerations in Airborne Systems and Equipment Certification [\[28\]](#).

Alle angegebenen Dokumente können als Quellen für das vorliegende Dokument angesehen werden.

Das vorliegende Dokument ist Teil der Normenreihe IEC 62443, die IT-Sicherheitsanforderungen für Entwickler beliebiger Produkte für industrielle Automatisierungssysteme beinhaltet, sofern die IT-Sicherheit von Belang ist.

[Bild 1](#) veranschaulicht die Beziehung der verschiedenen Teile von IEC 62443, die zum Zeitpunkt der Zirkulation dieses Dokuments vorlagen bzw. geplant waren. Die normativen Dokumente sind in der Liste der normativen Verweisungen in [Abschnitt 2](#) aufgeführt und die Dokumente, die nur informativ angewendet werden oder in Vorbereitung sind, sind in den Literaturhinweisen enthalten.

¹ Ziffern in eckigen Klammern verweisen auf die Literaturhinweise.

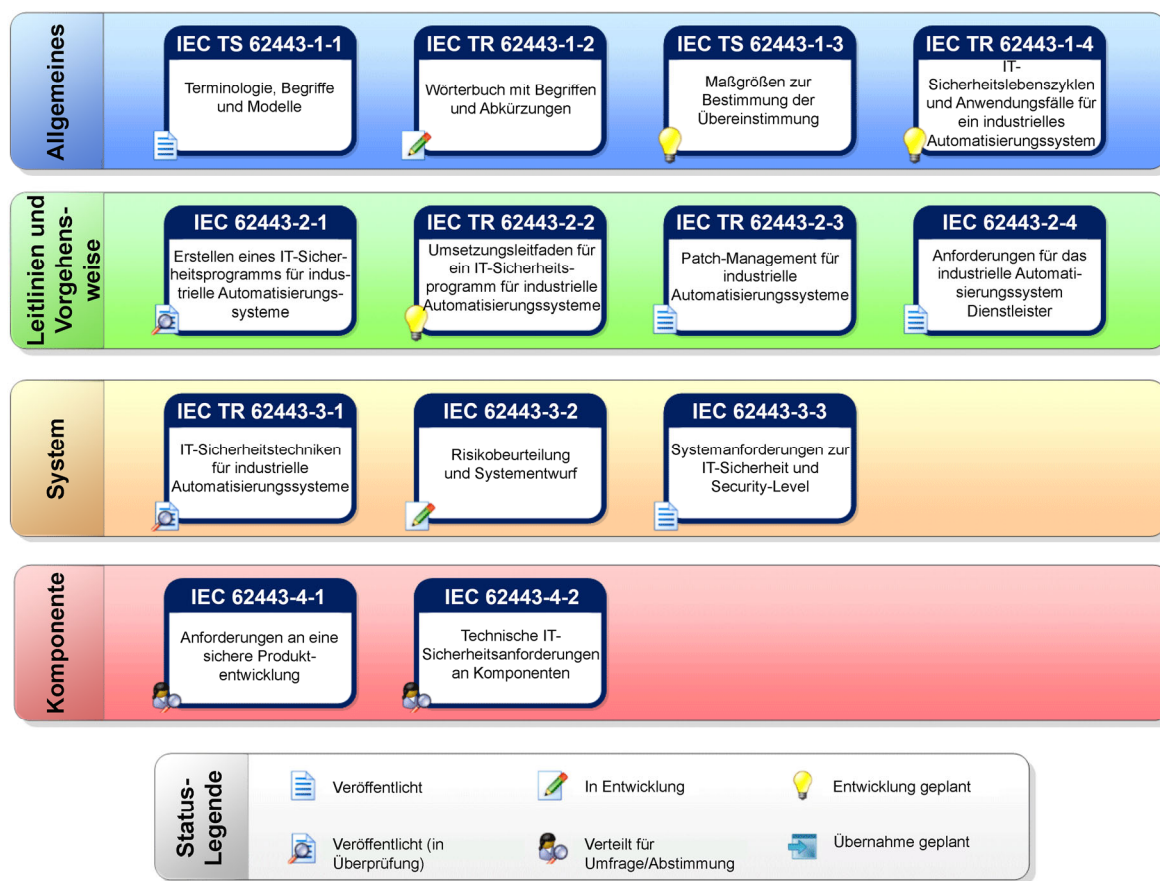


Bild 1 – Teile der Normenreihe IEC 62443

Bild 2 veranschaulicht, wie die entwickelten Produkte mit den in IEC 62443-2-4 definierten Instandhaltungs- und Integrationsfähigkeiten und mit ihrem Betrieb durch den Betreiber in Verbindung stehen. Der Hersteller entwickelt Produkte mithilfe eines mit dem vorliegenden Dokument übereinstimmenden Prozesses. Diese Produkte dürfen eine einzelne Komponente wie eine eingebettete Steuerung sein oder eine Gruppe von Komponenten, die als System oder Teilsystem zusammenwirken. Die Produkte werden dann in der Regel von einem Systemintegrator mit einem Prozess nach IEC 62443-2-4 in eine Automatisierungslösung integriert. Anschließend wird die Automatisierungslösung an einem bestimmten Standort installiert und Teil des industriellen Automatisierungssystems (IACS). Einige dieser Fähigkeiten beziehen sich auf die in IEC 62443-3-3 [10] festgelegten IT-Sicherheitsmaßnahmen, die vom Dienstleister in der Automatisierungslösung sicher unterstützt werden (entweder als Produktmerkmale oder als Kompensationsmechanismen). Das vorliegende Dokument betrifft nur den für die Entwicklung des Produkts angewendeten Prozess; es ist nicht auf den Entwurf, die Installation oder den Betrieb der Automatisierungslösung oder des IACS ausgerichtet.

In Bild 2 wird die Automatisierungslösung mit einem oder mehreren Teilsystem(en) und wahlfreien Zusatzkomponenten wie einer hochentwickelten Steuerung dargestellt. Die mit Strichlinien umrandeten Felder geben an, dass diese Komponenten wahlfrei sind.

ANMERKUNG 1 Automatisierungslösungen bestehen in der Regel aus einem einzelnen Produkt, sie sind aber nicht darauf beschränkt. In manchen Industrien liegt möglicherweise eine hierarchische Produktstruktur vor. Im Allgemeinen setzt sich die Automatisierungslösung unabhängig von der Bauform des Produkts aus einer Menge von Hardware und Softwareelementen zusammen, mit denen ein physikalischer Prozess (z. B. ein kontinuierlicher Prozess oder ein Herstellungsprozess) nach den Festlegungen des Betreibers gesteuert wird.

ANMERKUNG 2 Wenn ein Dienstleister Produkte für den Einsatz in Automatisierungslösungen bereitstellt, übernimmt er in dieser grafischen Darstellung die Rolle eines Herstellers.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10
EN IEC 62443-4-1:2018

ANMERKUNG 3 Wenn ein Dienstleister Produkte für den Einsatz in Automatisierungslösungen bereitstellt, übernimmt er in dieser grafischen Darstellung die Rolle eines Herstellers.

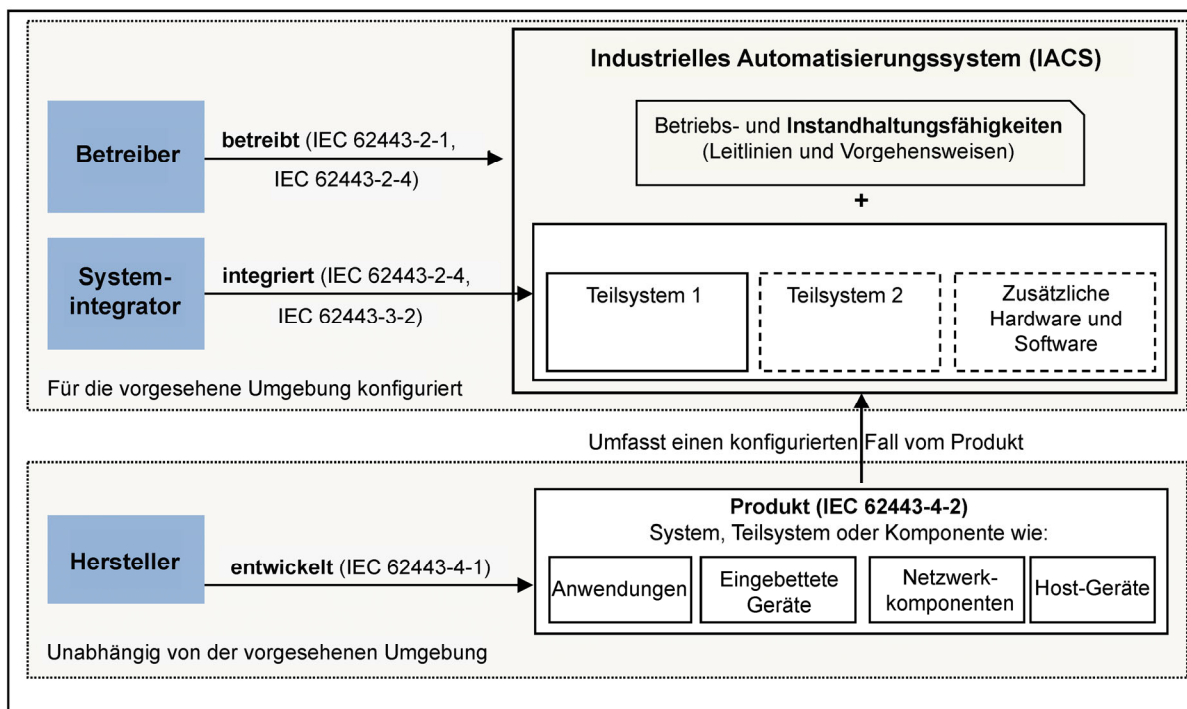


Bild 2 – Beispiel für den Anwendungsbereich eines Produktlebenszyklus

1 Anwendungsbereich

Dieser Teil von IEC 62443 legt Anforderungen an den gesicherten Entwicklungsprozess für Produkte fest, die in industriellen Automatisierungssystemen eingesetzt werden. Er definiert einen gesicherten Entwicklungslebenszyklus (SDL) zum Zweck der Entwicklung und Instandhaltung sicherer Produkte. Dieser Lebenszyklus umfasst die Definition von IT-Sicherheitsanforderungen, einen gesicherten Entwurf, eine sichere Implementierung (einschließlich Programmierrichtlinien), Verifikation und Validierung, eine Mängelbehandlung, ein Patch-Management und das Ende des Produktlebenszyklus. Diese Anforderungen können für neue oder vorhandene Prozesse der Entwicklung, der Instandhaltung und Pflege sowie der Zurückziehung von Hardware, Software oder Firmware für neue oder vorhandene Produkte angewendet werden. Diese Anforderungen gelten für den Entwickler und Instandhalter des Produkts, jedoch nicht für den Integrator oder einen Produktanwender. Eine Zusammenfassung der Anforderungen des vorliegenden Dokuments ist in [Anhang B](#) enthalten.

2 Normative Verweisungen

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

IEC 62443-2-4:2015, *IT-Sicherheit für industrielle Automatisierungssysteme – Part 2-4: Security program requirements for IACS service providers*

IEC 62443-2-4:2015/AMD1:2017

3 Begriffe, Abkürzungen, Akronyme und Vereinbarungen

3.1 Begriffe

Für die Anwendung dieses Dokuments gelten die Begriffe nach IEC TR 62443-1-2² und die folgenden Begriffe.

ISO und IEC stellen terminologische Datenbanken für die Verwendung in der Normung unter den folgenden Adressen bereit:

- IEC Electropedia: unter <http://www.electropedia.org/>
- ISO Online Browsing Platform: unter <http://www.iso.org/obp>

3.1.1

Missbrauchsfall

(en: abuse case)

Prüffall zur Durchführung einer negativen Arbeitsweise eines Anwendungsfalls

Anmerkung 1 zum Begriff: Missbrauchsprüfungen sind nachgebildete Angriffe, die häufig auf dem Bedrohungsmodell beruhen. Ein Missbrauchsfall ist ein Typ einer vollständigen Wechselwirkung zwischen einem System und einem oder mehreren Akteur(en), wobei die Ergebnisse der Wechselwirkung bewusst schädlich für das System, einen der Akteure oder eine der Interessengruppen im System sind.

3.1.2

Zugriffskontrolle

(en: access control)

<Schutz> Schutz einer Systemressource gegen nicht autorisierten Zugriff

² In Beratung.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 **EN IEC 62443-4-1:2018**

3.1.3

Zugriffskontrolle

(en: access control)

<Prozess> Vorgang, der die Verwendung von Systemressourcen gemäß einer Sicherheitsleitlinie regelt und der ausschließlich von dazu berechtigten Stellen gemäß dieser Leitlinie erlaubt wird

Anmerkung 1 zum Begriff: Zugriffskontrolle umfasst die Anforderungen an die Identifizierung und Authentifikation, die in anderen Teilen der Normenreihe IEC 62443 festgelegt sind.

3.1.4

Administrator

(en: administrator)

Nutzer, der zur Verwaltung von IT-Sicherheitsrichtlinien und -fähigkeiten für ein Produkt oder ein System autorisiert ist

3.1.5

Schutzobjekt

(en: asset)

physikalisches oder logisches Objekt im Eigentum oder in der Obhut einer Organisation, das für diese Organisation entweder einen wahrgenommenen oder einen tatsächlichen Wert hat

Anmerkung 1 zum Begriff: In diesem spezifischen Fall ist ein Schutzobjekt ein Objekt, das Teil eines IACS ist.

3.1.6

Betreiber

(en: asset owner)

Person oder Organisation, die für ein oder mehrere IACS verantwortlich ist

3.1.7

Angriffsfläche

(en: attack surface)

physikalische und funktionale Schnittstellen eines Systems, die zugänglich sind und dadurch von einem Angreifer möglicherweise ausgenutzt werden können

3.1.8

Ereignisprotokoll

(en: audit log)

Ereignisprotokoll, das einen höheren Integritätsschutz erfordert, als ihn typische Ereignisprotokolle bieten

Anmerkung 1 zum Begriff: Auditprotokolle dienen dem Schutz gegen Ansprüche, die aus der Nichtanerkennung der Verantwortlichkeit für eine Aktion resultieren.

3.1.9

Authentifikation

(en: authentication)

Bereitstellung einer Zusicherung, dass die Behauptung eines Merkmals einer Identität ordnungsgemäß ist

Anmerkung 1 zum Begriff: Nicht alle Identitätsnachweise zur Authentifikation einer Identität werden auf die gleiche Weise erzeugt. Die Vertrauenswürdigkeit des Identitätsnachweises wird durch den konfigurierten Authentifikationsmechanismus bestimmt. Auf Hardware oder Software basierende Mechanismen können Nutzer dazu zwingen, ihre Identität nachzuweisen, bevor auf Daten auf einem Gerät zugegriffen werden kann. Ein typisches Beispiel ist der gewöhnliche Nachweis der Identität eines Nutzers durch einen Identitätsanbieter.

Anmerkung 2 zum Begriff: Authentifikation schließt sowohl die Bestätigung menschlicher Nutzer als auch nicht-menschlicher Nutzer, z. B. Geräte oder Prozesse, ein.

3.1.10**Automatisierungslösung**

(en: automation solution)

Automatisierungssystem und weitere zusätzliche Hardware- und Softwarekomponenten, die zum Betrieb in einem IACS aufgebaut und konfiguriert wurden

Anmerkung 1 zum Begriff: Der Begriff „Automatisierungslösung“ wird in diesem Teil der Normenreihe IEC 62443 als ein Eigenname verwendet.

Anmerkung 1 zum Begriff: Der Unterschied zwischen dem Automatisierungssystem und der Automatisierungslösung besteht darin, dass das Automatisierungssystem in den Entwurf der Automatisierungslösung eingebunden wird (z. B. eine bestimmte Anzahl von Arbeitsplatzrechnern, Steuerungen und Geräten in einer spezifischen Konfiguration), der dann umgesetzt wird. Die sich so ergebende Konfiguration wird dann als die Automatisierungslösung bezeichnet.

Anmerkung 3 zum Begriff: Die Automatisierungslösung kann Komponenten verschiedener Hersteller einschließlich des Herstellers des Automatisierungssystems umfassen.

3.1.11**verbotene Funktion**

(en: banned function)

Softwaremethode, die nicht mehr für die Anwendung in der Software empfohlen wird, weil besser gesicherte Versionen mit weniger Anfälligkeit für einen Missbrauch vorhanden sind

Anmerkung 1 zum Begriff: Verbotene Funktionen werden mitunter als verbotene Methoden oder verbotene Anwendungsprogrammierschnittstellen (API) bezeichnet.

3.1.12**bewährte Verfahren**

(en: best practices)

Richtlinien für ein gesichertes Auslegen, Entwickeln, Prüfen, Instandhalten oder Zurückziehen von Produkten, für welche der Hersteller bestimmt hat, dass sie von der Sicherheitsgemeinschaft sowie der Gemeinschaft für industrielle Automatisierung gemeinsam empfohlen werden

BEISPIEL Minimal erforderliche Rechte, einfache Schutzmechanismen und Minimum an gemeinsamen Mechanismen.

3.1.13**Komponente**

eines der Teile, die ein Produkt oder System bilden

Anmerkung 1 zum Begriff: Eine Komponente darf eine Hardware oder eine Software sein und darf in weitere Komponenten unterteilt sein.

3.1.14**Konfigurationsverwaltung**

(en: configuration management)

Einordnung der Komponenten eines entstehenden Systems zur Kontrolle von Änderungen dieser Komponenten und Erhaltung der Kontinuität und Rückverfolgbarkeit während des gesamten Lebenszyklus

3.1.15**Defense-in-Depth-Konzept**

(en: defense in depth)

Ansatz zur Verteidigung des Systems gegen einen beliebigen bestimmten Angriff mit Anwendung mehrerer unabhängiger Methoden

Anmerkung 1 zum Begriff: Ein Defense-in-Depth-Konzept bedingt selbst bei Einzelsystemen IT-Sicherheits- und Erkennungsschichten und hat folgende Merkmale:

- beruht auf dem Grundgedanken, dass jede Schutzmaßnahme überwunden werden kann und wahrscheinlich auch überwunden wird;

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 **EN IEC 62443-4-1:2018**

- Angreifer müssen jede Schicht überwinden oder umgehen, ohne dabei erkannt zu werden;
- eine Schwachstelle in einer Schicht kann durch die Fähigkeiten der anderen Schichten abgeschwächt werden;
- die IT-Sicherheit des Systems wird zu einem Satz von Schichten innerhalb der gesamten IT-Netzwerk-Sicherheit; und
- jede Schicht sollte eigenständig sein und nicht auf der gleichen Funktionalität wie die anderen Schichten beruhen, und sollte nicht die gleichen Ausfallarten wie diese aufweisen.

3.1.16

abhängige Komponente

(en: dependent component)

externe Produktkomponente, von der das Produkt abhängt

BEISPIEL Java-Laufzeitumgebung oder ein Treiber.

Anmerkung 1 zum Begriff: Dazu gehören sowohl Hardware als auch Software.

3.1.17

abgelehnte Funktion

(en: deprecated function)

Softwaremethode, die zwar unterstützt wird, deren Nutzung aber nicht mehr empfohlen wird

Anmerkung 1 zum Begriff: Methoden werden grundsätzlich abgelehnt, bevor sie obsolet (aus dem vom Hersteller zur Verfügung gestellten Funktionssatz gelöscht) werden. Abgelehnte Funktionen werden mitunter als abgelehnte Methoden oder abgelehnte API bezeichnet.

3.1.18

extern bereitgestellte Komponente

(en: externally provides component)

in das Produkt integrierte Komponente, die von einer externen Organisation entwickelt wurde und nicht speziell für einen Hersteller entwickelt wurde

Anmerkung 1 zum Begriff: Beispiele schließen gekaufte Software und Open-Source-Software ein.

3.1.19

Fuzzing

Fuzz-Prüfung

(en: fuzz testing)

Prozess der Erzeugung verfälschter oder unerwarteter Daten oder Aufruffolgen zur Eingabe in die zu prüfende Einheit für den Nachweis, ordnungsgemäß

3.1.20

industrielles Automatisierungssystem

(en: industrial automation und control system, IACS)

Zusammenstellung von Personal, Hardware, Software, Vorgehensweisen und Leitlinien, die in den Betrieb eines industriellen Prozesses eingebunden sind und dessen sicheren und zuverlässigen Betrieb beeinträchtigen oder beeinflussen können

Anmerkung 1 zum Begriff: Das IACS darf Komponenten umfassen, die nicht am Standort des Betreibers errichtet sind.

Anmerkung 2 zum Begriff: Die Definition des IACS wurde IEC 62443-3-3 [10] entnommen und ist in Bild 2 dargestellt.

3.1.21

Patch-Management

(en: patch management)

Bereich der Systemverwaltung, zu dem der Erwerb, die Prüfung und die Installation von Softwarepatches (Codeänderungen) für ein Produkt gehören

Anmerkung 1 zum Begriff: Weitere Informationen können IEC TR 62443-2-3 [7] entnommen werden.

Anmerkung 2 zum Begriff: Das Patch-Management wird auch für den Prozess angewendet, mit dem eingebettete Fremdbibliotheken auf dem aktuellen Stand gehalten werden, bevor ein Produkt freigegeben wird.

3.1.22

Produkt

(en: product)

System, Teilsystem oder Komponente, das bzw. die zur Verwendung durch andere Produkte hergestellt, entwickelt oder weiterverarbeitet wird

Anmerkung 1 zum Begriff: Die Prozesse, die von den im vorliegenden Dokument definierten Ansätzen gefordert werden, sind iterativ auf allen Ebenen des Produktentwurfs (z. B. von der Systemebene bis zur Komponentenebene) anwendbar.

3.1.23

IT-Sicherheitsumfeld des Produkts

(en: product security context)

IT-Sicherheit, die dem Produkt durch die Umgebung (Einsatz beim Betreiber), in der der Einsatz des Produkts vorgesehen ist, geboten wird

Anmerkung 1 zum Begriff: Die IT-Sicherheit, die dem Produkt durch die vorgesehene Umgebung geboten wird, kann die für das Produkt zutreffenden Bedrohungen wirksam einschränken.

3.1.24

Hersteller

(en: product supplier)

Hersteller eines Hardware- und/oder Softwareprodukts

Anmerkung 1 zum Begriff: Zum Hersteller gehört auch die Stelle, die für den Entwurf und die Instandhaltung eines Produkts verantwortlich ist und die über den reinen Produzenten hinausgehen kann (z. B. Integrator).

3.1.25

Produktanwender

(en: product users)

Anwender des Hardware- und/oder Softwareprodukts einschließlich Betreiber, Integratoren und Instandhaltungspersonal, Anbieter anderer Komponenten oder Produkte, welche dieses Produkt wiederverwenden oder enthalten

3.1.26

Aufzeichnung

(en: record)

Dokument, in dem erreichte Ergebnisse oder Nachweise von ausgeführten Aktivitäten angegeben sind

Anmerkung 1 zum Begriff: Der Begriff „Artefakt“ wird häufig gleichbedeutend verwendet.

3.1.27

Regression

(en: regression)

Abänderung an einer Systemkomponente, die Funktionalität, Zuverlässigkeit oder Leistungsfähigkeit nachteilig beeinflusst hat oder zusätzliche Mängel eingebracht hat

3.1.28

Grundursache

(en: root cause)

Auslöser eines Zustands oder einer Ursachenkette, der/die zu einem Ergebnis oder einer Wirkung führt, das/die von Interesse ist

Anmerkung 1 zum Begriff: Diese Schwachstellen resultieren häufig aus der Fehlanwendung bewährter Verfahren.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10
EN IEC 62443-4-1:2018

3.1.29

IT-Sicherheitsmangel

(en: security defect)

Mangel des Entwurfs oder der Implementierung, der mit dem Ziel der Gefährdung eines Schutzobjekts oder einer Ressource ausgenutzt werden kann

3.1.30

Sicherheitsberater

Organisatorische Rolle zur Führung eines Teams im Prozess des SDL (gesicherten Entwicklungslebenszyklus)

Anmerkung 1 zum Begriff: Ein Sicherheitsberater darf Bestandteil eines Projektteams sein oder darf ein Berater des Teams zur Bereitstellung von Anleitung und Unterstützung im Bedarfsfall sein.

3.1.31

IT-Sicherheitsvorfall

(en: security incident)

IT-Sicherheitsverstoß, der für den Betreiber von Bedeutung ist, oder ein fehlgeschlagener Versuch der Gefährdung des Systems, deren Ergebnis für den Betreiber von Bedeutung hätte sein können

Anmerkung 1 zum Begriff: Der Begriff „Beinahevorfall“ (en: near miss) wird mitunter gebraucht, um ein Ereignis zu beschreiben, das unter geringfügig anderen Umständen ein Vorfall hätte sein können.

3.1.32

sicherheitsbezogenes Problem

(en: security-related issue)

Entwurfs- oder Implementierungseigenschaft des Produkts, die die IT-Sicherheit des Produkts unter Umständen beeinflussen kann

3.1.33

Verifikations- und Validierungsprüfung der IT-Sicherheit

(en: security verification and validation testing)

Prüfung zur Bewertung der IT-Gesamtsicherheit einer Komponente, eines Produkts oder eines Systems, wenn diese bzw. dieses im vorgesehenen IT-Sicherheitsumfeld eingesetzt wird, und zur Bestimmung, ob eine Komponente, ein Produkt oder ein System sowohl die IT-Sicherheitsanforderungen für das Produkt als auch seinen Sicherheitszweck gemäß der Auslegung erfüllt

Anmerkung 1 zum Begriff: Die Verifikationsprüfung der IT-Sicherheit ergänzt die Validierungsprüfung der IT-Sicherheit um eine weitere Prüfung, die auf das IT-Sicherheitsumfeld des Produkts und die Defense-in-Depth-Strategie ausgerichtet ist.

3.1.34

Systemintegrator

(en: system integrator)

Person oder Gesellschaft, die sich darauf spezialisiert hat, Teilsysteme von Komponenten zu einem ganzen System zusammenzufügen, und die dafür sorgt, dass diese Teilsysteme sich entsprechend den Projektspezifikationen verhalten

3.1.35

Fremdanbieter

(en: third party supplier)

Gesellschaft, die von der Organisation des Produktherstellers unabhängig ist

3.1.36

Bedrohung

(en: threat)

Umstand oder Ereignis, bei dem die Möglichkeit einer nachteiligen Beeinflussung von Operationen (einschließlich Mission, Funktionen, Ruf oder Ansehen), Schutzobjekten, Automatisierungssystemen oder Einzelpersonen durch nicht autorisierten Zugriff, Zerstörung, Offenlegung, Abänderung von Daten und/oder Denial-of-Service-Angriff besteht

3.1.37**Bedrohungsmodell**

(en: threat modelling)

Analyseverfahren für den Entwurf der IT-Sicherheit, mit dem mögliche IT-Sicherheitsprobleme festgestellt werden können

Anmerkung 1 zum Begriff: Bedrohungsmodelle werden von Software- und Hardwarearchitekten häufig synonym mit Attack-Trees zur Feststellung und Abschwächung möglicher IT-Sicherheitsprobleme in einer frühen Phase benutzt, in der sie relativ einfach und kostengünstig zu lösen sind.

3.1.38**Vertrauensgrenze**

(en: trust boundary)

Element eines Bedrohungsmodells, das eine Grenze beschreibt, an der eine Authentifikation erforderlich ist oder ein Wechsel der Vertrauensstufe (von einer höheren zu einer niedrigeren Stufe oder umgekehrt) stattfindet

Anmerkung 1 zum Begriff: Zu Durchsetzungsmechanismen der Vertrauensgrenze für Produktanwender gehören in der Regel Authentifikation (z. B. Frage/Antwort, Passwörter, biometrische oder digitale Signaturen) und die zugehörige Autorisierung (z. B. Regeln der Zugriffskontrolle).

Anmerkung 2 zum Begriff: Zu Durchsetzungsmechanismen der Vertrauensgrenze für Daten gehören in der Regel die Authentifikation der Quelle (z. B. Nachrichtenauthentifikationscodes oder digitale Signaturen) und/oder die Validierung des Inhalts.

3.1.39**Unittest**

(en: unit test)

Verifikation, dass eine einzelne Einheit der Computersoftware oder -hardware die vorgesehene Funktion erfüllt

Anmerkung 1 zum Begriff: Ein automatisierter Nachweis oder eine automatisierte Prüfung wird im Allgemeinen von einer Computerprüfsoftware durchgeführt.

Anmerkung 2 zum Begriff: Was eine Einheit eines Quellcodes ist, ist eine Entwurfsentscheidung. Eine Einheit wird häufig als der kleinste prüfbare Teil einer Anwendung entworfen. Dazu können eine oder mehrere Einheit(en) eines Computerprogramms oder auch zugehörige Steuerdaten, Anwendungs- und Betriebsprozeduren gehören. Bei der prozeduralen Programmierung kann eine Einheit ein gesamtes Modul sein, aber häufiger handelt es sich um eine einzelne Funktion oder eine Prozedur. Bei der objektorientierten Programmierung ist eine Einheit häufig eine gesamte Schnittstelle, z. B. eine Klasse, sie kann aber auch eine einzelne Methode sein.

3.1.40**Nutzer**

(en: user)

Person, Organisationseinheit oder automatisierter Prozess, die/der auf ein System zugreift, unabhängig davon ob dies autorisiert oder nicht autorisiert erfolgt

3.1.41**Zone**

(en: zone)

Sammlung von Einheiten, welche die Aufteilung eines Systems unter Berücksichtigung der grundlegenden funktionalen, logischen und physikalischen (einschließlich Standort) Beziehung abbildet

Anmerkung 1 zum Begriff: Zonen werden häufig auf der Grundlage gemeinsamer Sicherheitsanforderungen, Kritikalität (z. B. hohe Finanzen, Gesundheit, Sicherheit oder Umweltauswirkungen), Funktionalität, logischer oder physikalischen (einschließlich Standort) Beziehung erstellt.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

3.2 Abkürzungen und Akronyme

Im vorliegenden Dokument werden die folgenden Abkürzungen und Akronyme verwendet.

ACL	Zugriffskontrollliste (en: Access Control List)
CMMI	Reifegradmodell (en: Capability Maturity Model Integration)
CMMI-DEV	Reifegradmodell für die Entwicklung (en: Capability Maturity Model Integration for Development)
CMU	Carnegie Mellon Universität
COTS	handelsüblich (en: Commercial Off The Shelf)
CVSS	allgemeines Verwundbarkeitsbewertungssystem (en: Common Vulnerability Scoring System)
DM	Mängelbehandlung (en: Defect Management)
e.g.	zum Beispiel (en: exempli gratia)
FDIS	Schluss-Entwurf einer Internationalen Norm (en: Final Draft International Standard)
HTTP	Hypertext-Übertragungsprotokoll (en: Hypertext Transfer Protocol)
IACS	industrielles Automatisierungssystem (en: Industrial Automation and Control System(s))
IEC	Internationale Elektrotechnische Kommission (en: International Electrotechnical Commission)
ISA	International Society of Automation
ISO	Internationale Organisation für Normung (en: International Organisation for Standardization)
MIN	Minimum
OWASP	Open Web Application Security Project
SL-C	erreichbarer Security-Level (en: Capability Security Level)
SCA	statische Codeanalyse (en: Static Code Analysis)
SD	gesicherter Entwurf (en: Secure Design)
SDL	gesicherter Entwicklungslebenszyklus (en: Security Development Life-cycle)
SDLA	Bewertung des gesicherten Entwicklungslebenszyklus (en: Secure Development Life-Cycle Assessment)
SEI	Software Engineering Institute
SG	IT-Sicherheitsrichtlinien (en: security guidelines)
SI	gesicherte Implementierung (en: Secure Implementation)
SM	IT-Sicherheitsmanagement (en: Security Management)
SR	IT-Sicherheitsanforderungen (en: Security Requirements)
STRIDE	Vortäuschung, Manipulation, Nichtanerkennung, Offenlegung von Informationen, Denial-of-Service-Angriff, Rechteauserweiterung (en: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege)
SVV	Verifikations- und Validierungsprüfung der IT-Sicherheit (en: Security Verification and Validation)
TCP	Übertragungssteuerungsprotokoll (en: Transmission Control Protocol)
TCP/IP	Übertragungssteuerungsprotokoll/Internetprotokoll (en: Transmission Control Protocol/Internet Protocol)
TR	Technischer Bericht (en: Technical Report)
USB	universeller serieller Bus (en: Universal Serial Bus)

3.3 Vereinbarungen

Die im vorliegenden Dokument festgelegten Anforderungen beginnen in der Regel mit dem Wortlaut „Es muss ein Prozess angewendet werden ...“. Diese Terminologie wird verwendet, um festzulegen, dass die

erforderlichen Prozesse ein Teil des vom Hersteller des Produkts dokumentieren Produktentwicklungslebenszyklus sein müssen. Der Ansatz dieser Anforderungen hängt davon ab, ob der Hersteller Produktentwicklungsprojekte besitzt, die die Nutzung dieser Prozesse erfordern.

Nach 5.5 müssen Produkte, welche die Anwendung dieser Prozesse erfordern, gekennzeichnet werden.

4 Allgemeine Grundsätze

4.1 Ziele

Das Hauptziel dieser Anforderungen besteht in der Bereitstellung einer Rahmenstruktur, die einen Ansatz für den Entwurf, den Aufbau, die Instandhaltung und das Zurückziehen von Produkten und Systemen der industriellen Automatisierung bietet, der IT-Sicherheit durch den Entwurf (Secure by Design) und ein Defense-in-Depth-Konzept (Defense in Depth) behandelt. Die Anwendung der Rahmenstruktur bietet das Vertrauen, dass die Komponente, das Produkt oder das System eine IT-Sicherheit aufweist, die der erwarteten Risikostufe während des gesamten Produktlebenszyklus angemessen ist. Während das Konzept der Security-Level (de: Sicherheitsstufen) im vorliegenden Dokument nicht erörtert wird, stellt die Einhaltung des vorliegenden Dokuments sicher, dass die im Produkt umgesetzten Fähigkeiten im Hinblick auf die IT-Sicherheit (siehe IEC 62443-4-2³ [11]) ordnungsgemäß umgesetzt werden, und dass jegliche bekannte Sicherheitslücken im Produkt beseitigt oder abgeschwächt werden. Folglich unterstützt die Einhaltung des vorliegenden Dokuments die Einhaltung des erreichbaren Security-Levels (SL-C) des Produkts.

Das sekundäre Ziel dieser Anforderungen ist die Anpassung des Entwicklungsprozesses an die verstärkten Bedürfnisse der Nutzer von Produkten industrieller Automatisierungssysteme (z. B. Anbieter von Fähigkeiten nach IEC 62443-2-4 wie Integratoren und Instandhaltungsdienstleister) nach IT-Sicherheit. Das bedeutet, dass der Prozess Ergebnisse wie gut dokumentierte IT-Sicherheitskonfigurationen und Leitlinien und Vorgehensweisen der Patch-Management erzeugen sowie eindeutige und knappe Mitteilungen über im Produkt offengelegte IT-Sicherheitslücken bereitstellen muss.

ANMERKUNG 1 IEC 62443-3-2⁴ [9] beschreibt Anforderungen für die Bestimmung der erwarteten Risikostufe von IACS, die mit den Zonen und Conduits des Systems verbunden sind.

Bild 3 veranschaulicht, wie die Grundsätze der IT-Sicherheit durch den Entwurf im vorliegenden Dokument zur Defense-in-Depth-Strategie für das Produkt beitragen. Der Ansatz der Verwaltung der IT-Sicherheit ist im äußersten Kreis dargestellt, da sie während aller anderen Ansätze Anwendung findet, um sicherzustellen, dass die Ansätze befolgt und verwaltet werden. Die anderen Ansätze, dargestellt im zweiten Kreis, werden während des Entwicklungslebenszyklus angewendet, häufig in einem iterativen Muster. Diese Ansätze tragen alle zur Defense-in-Depth-Strategie bei, die in der Mitte des Kreises dargestellt ist, da sie das Hauptergebnis der Befolgung des gesicherten Entwicklungslebenszyklus abbildet. Die Mängelbehandlung und die Verwaltung von IT-Sicherheits-Updates stellen bestätigte Instandsetzungen für die gesicherte Implementierung bereit, und fallen in dieser graphischen Darstellung in die Kategorie des gesamten IT-Sicherheitsmanagement.

³ In Vorbereitung. Stufe zur Zeit der Veröffentlichung: IEC/CDV 62443-4-2:2017.

⁴ In Vorbereitung. Stufe zur Zeit der Veröffentlichung: IEC/CDV 62443-3-2:2017.

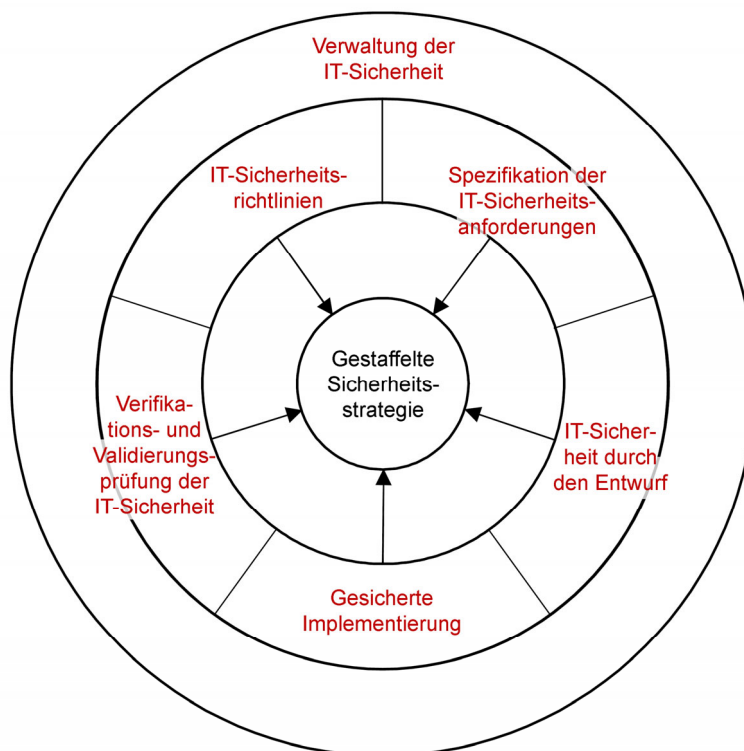


Bild 3 – Eine Defense-in-Depth-Strategie ist ein Kerngedanke des gesicherten Produktlebenszyklus

Eine Kernidee des vorliegenden Dokuments ist die Anwendung eines Bedrohungsmodells. Entwurfs- und Implementierungsüberprüfungen zur Weiterentwicklung der Arbeitsergebnisse verbessern die Sicherheitslage eines Produkts. Zur Feststellung sicherheitsbezogener Probleme im Produkt werden Überprüfungen jeglicher Arbeitsergebnisse (z. B. Anforderungen, Entwurfsartefakte, implementierte Module und Verifikations-/Validierungsprüfungen) durch beliebige Mittel (z. B. manuell, automatisiert oder als Kombination) durchgeführt. Eine Auswirkungsanalyse für jedes festgestellte Problem bewertet dessen Schweregrad für die IT-Sicherheit auf der Grundlage seiner möglichen Gefährdung (z. B. Verfügbarkeit, Integrität und Vertraulichkeit) und der damit verbundenen Verluste (z. B. Lenkung des Prozesses, Ansicht des Prozesses und geistiges Eigentum). Anschließend bestimmt der Lösungsprozess die am besten geeignete Vorgehensweise auf der Grundlage des Schweregrads des Problems und die Eignung verschiedener Reaktionsmöglichkeiten.

4.2 Reifegradmodell

Es liegt eine Reihe von Verfahren vor, durch welche ein Produkthersteller die im vorliegenden Dokument festgelegten Anforderungen einhalten könnte. Das Reifegradmodell legt Vergleichswerte für die Einhaltung dieser Anforderungen fest.

Diese Vergleichswerte sind durch Reifegrade festgelegt, wie in [Tabelle 1](#) angegeben. Die Reifegrade beruhen auf dem Reifegradmodell (CMMI) für das Reifegradmodell für die Entwicklung (CMMI-DEV) [42]. In der Spalte „Beschreibung“ in [Tabelle 1](#) wird die Beziehung zum CMMI-DEV angegeben.

Reifegrade bieten mehr Einzelheiten in Bezug darauf, wie sorgfältig ein Hersteller die Anforderungen erfüllt hat. Folglich könne diese Grade durch Systemintegratoren und Betreiber verwendet werden, um den bei der Entwicklung von Produkten angewendeten Genauigkeitsgrad zu bewerten.

Der in diesem Abschnitt beschriebene Zweck der Reifegrade ist es, einer Organisation einen Vergleichswert bereitzustellen, um ihre Bereitschaft zur Anwendung ihrer Prozesse und Verfahren für Entwurf und Implementierung eines sicheren Produkts festzulegen. Die Verwendung dieser Vergleichswerte macht es möglich, dass eine Organisation feststellt, dass sie nicht zur Umsetzung aller Anforderungen bis zum gleichen Reifegrad bereit ist.

Bei Entwurf und Implementierung eines sicheren Produkts nach dem vorliegenden Dokument (siehe IEC 62443-4-2 und IEC 62443-3-3) müssen alle anwendbaren Anforderungen gemäß den Festlegungen nach SM-5 (Prozesseingrenzung) im vorliegenden Dokument erfüllt werden und im Entwicklungslebenszyklus des Produkts verwendet werden, unabhängig vom Reifegrad der Organisation. SM-5 sieht von Fall zu Fall Ausnahmen für die Anwendbarkeit von Anforderungen vor.

ANMERKUNG 1 Industriegruppen/Branchen dürfen diejenigen Reifegrade angeben/wählen, die ihre eigenen Bedürfnisse am besten erfüllen.

ANMERKUNG 2 Es ist vorgesehen, dass sich die Entwicklungsfähigkeiten der Hersteller im Laufe der Zeit und für eine spezifische Anforderung in dem Maß zu höheren Graden entwickeln, wie sie Fertigkeiten bei der Erfüllung dieser Anforderungen erlangen. Die Evolutionsrate variiert häufig für jede Anforderung. Zum Beispiel erreicht ein Produkt-hersteller möglicherweise Grad 4 für Ansatz 6 Monate oder Jahre bevor er Grad 4 für Ansatz 5 erreicht.

ANMERKUNG 3 Diese Reifegrade wurden für Organisationen als Maß und für die Mitteilung ihrer Übereinstimmung mit dem vorliegenden Dokument festgelegt. Das Modell erlaubt Organisationen, sich zu höheren Reifegraden der Fähigkeiten für ihre Prozesse hin weiterzuentwickeln.

ANMERKUNG 4 Eine ständige durch Maßnahmen vorangetriebene Verbesserung ist wichtig für eine Verbesserung des Reifegrads eines Produktherstellers für jeden Ansatz im vorliegenden Dokument. Da beste Verfahren für eine Entwicklung sicherer Produkte einer Weiterentwicklung unterliegen, müssen Produkthersteller außerdem die besten neuen Praktiken auswählen und implementieren.

Tabelle 1 – Reifegrade (1 von 2)

Grad	CMMI-DEV	IEC 62443-4-1	IEC 62443-4-1 Beschreibung
1	Anfang	Anfang	Hersteller führen die Produktentwicklung in der Regel für den Einzelfall und häufig undokumentiert (oder unvollständig dokumentiert) durch. Als Ergebnis sind die Beständigkeit des Projekts und die Wiederholbarkeit des Prozesses unter Umständen nicht möglich.
2	Verwaltet	Verwaltet	Bei diesem Grad hat der Hersteller die Fähigkeit, die Entwicklung eines Produkts nach den schriftlich niedergelegten Leitlinien (einschließlich Ziele) zu verwalten. Der Hersteller kann außerdem nachweisen, dass das Personal, das den Prozess durchführen wird, die Fachkenntnisse zur Durchführung hat, dafür ausgebildet ist und/oder nach schriftlichen Vorgehensweisen arbeitet. Bei diesem Grad verfügt die Organisation jedoch nicht über die Erfahrung, Produkte nach allen schriftlichen Leitlinien zu entwickeln. Das wäre der Fall, wenn die Organisation ihre Vorgehensweisen aktualisiert hat, um dem vorliegenden Dokument zu entsprechen, aber noch nicht alle Vorgehensweisen in den tatsächlichen Ansatz überführt hat. Mit der durch Reifegrad 2 wiedergespiegelten Entwicklungsdisziplin wird sichergestellt, dass die Entwicklungsverfahren auch in Phasen großer Belastung wiederholbar sind. Wenn diese Vorgehensweisen eingeführt sind, werden sie nach ihren dokumentierten Plänen durchgeführt und verwaltet. ANMERKUNG Bei diesem Grad gleichen sich CMMI und die Reifegradmodelle nach IEC 62443-4-1 im Grunde, mit der Ausnahme, dass IEC 62443-4-1 anerkennt, dass es möglicherweise eine erhebliche Verzögerung zwischen der Definition/Formalisierung eines Prozesses und dessen Ausführung (Umsetzung in die Praxis) gibt. Deshalb werden die ausführungsbezogenen Aspekte des CMMI-DEV-Reifegrads 2 in Reifegrad 3 verschoben.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10
EN IEC 62443-4-1:2018

Tabelle 1 (2 von 2)

Grad	CMMI-DEV	IEC 62443-4-1	IEC 62443-4-1 Beschreibung
3	Definiert	Definiert (Eingeführt)	Die Leistungsfähigkeit eines Herstellers mit dem Reifegrad 3 ist innerhalb der Herstellerorganisation nachweislich wiederholbar. Die Prozesse sind durchgeführt worden und es liegen nachprüfbare Nachweise dafür vor. ANMERKUNG Bei diesem Grad gleichen sich CMMI und die Reifegradmodelle nach IEC 62443-4-1 im Grunde, mit der Ausnahme, dass die ausführungsbezogenen Aspekte des CMMI-DEV-Reifegrads 2 hier enthalten sind. Damit ist ein Prozess des Reifegrads 3 ein Prozess des Reifegrads 2, den der Hersteller für mindestens ein Produkt durchgeführt hat.
4	Quantitativ verwaltet	Ständige Verbesserung	Bei diesem Reifegrad fasst Teil 4-1 die CMMI-DEV-Reifegrade 4 und 5 zusammen. Unter Verwendung geeigneter Prozessmetriken kontrollieren Hersteller die Wirksamkeit und die Leistungsfähigkeit des Produkts und weisen eine ständige Verbesserung in diesen Bereichen nach.
5	Ständige Optimierung		

5 Ansatz 1 – Verwaltung der IT-Sicherheit

5.1 Zweck

Der Zweck des Ansatzes für das IT-Sicherheitsmanagement ist die Sicherstellung, dass die sicherheitsbezogenen Aktivitäten während des gesamten Produktlebenszyklus angemessen geplant, dokumentiert und ausgeführt werden.

Wenn die Aktivitäten im Zusammenhang mit der IT-Sicherheit nicht sorgfältig geplant und unterstützt werden, können sich diese Aktivitäten aufgrund unzureichender Ressourcen, mangelnder Zeit oder von Prozessschwächen als unwirksam erweisen. Auf die gleiche Weise können Unstimmigkeiten zwischen dem IT-Sicherheitsbedarf des Produkts und den zugehörigen Organisationsprozessen wie die Konfigurationsverwaltung, die Leitlinien und Vorgehensweisen der Informationstechnik und die Lieferkettenverwaltung die Wirksamkeit des gesicherten Entwicklungslebenszyklus für Produkte gefährden.

5.2 SM-1: Entwicklungsprozess

5.2.1 Anforderung

Es muss ein allgemeiner Prozess für Produktentwicklung/-instandhaltung/-unterstützung dokumentiert und durchgesetzt werden, der mit anerkannten Produktentwicklungsprozessen vereinbar und in diese eingebunden ist, und das schließt unter anderem ein:

- die Konfigurationsverwaltung mit Maßnahmen und Ereignisprotokollierung;
- die Produktbeschreibung und die Definition der Anforderungen mit der Rückverfolgbarkeit der Anforderungen;
- den Software- oder Hardwareentwurf und Implementierungsverfahren, z. B. ein modularer Entwurf;
- den wiederholbaren Verifikations- und Validierungsprozess;
- die Überprüfung und Zulassung aller Artefakte des Entwicklungsprozesses; und
- die Unterstützung während des Lebenszyklus.

5.3 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass beim Hersteller wohldefinierte und bewährte Produktentwicklungsprozesse vorhanden sind, die erweitert werden können, um die im vorliegenden Dokument festgelegten Anforderungen zu unterstützen. Die im vorliegenden Dokument definierten erforderlichen Prozesse setzen das Vorhandensein eines ausgereiften Entwicklungslebenszyklus für Produkte voraus. Gesicherte Entwicklungslebenszyklen für Produkte können ohne diese Prozesse

unwirksam sein und sie beruhen darauf, dass solche Prozesse vorhanden sind. Beispiele anerkannter Produktentwicklungsprozesse schließen mit ISO 9001 [13] und ISO/IEC 27034 [34] übereinstimmende Prozesse ein.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eines Produkts während des Entwicklungslebenszyklus für Produkte Verfahren nutzt, die mindestens die Konfigurationsverwaltung, die Festlegung von Anforderungen, den Entwurf, die Implementierung und die Prüfung unterstützen.

5.4 SM-2: Kennzeichnung von Verantwortlichkeiten

5.4.1 Anforderung

Es muss ein Prozess angewendet werden, der die organisatorischen Rollen und das Personal, das für die Aufgaben jedes der im vorliegenden Dokument geforderten Prozesse verantwortlich ist, kennzeichnet.

5.4.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass den Elementen der Herstellerorganisation Verantwortlichkeiten für die Durchführung und den Abschluss der im vorliegenden Dokument geforderten Prozesse zugewiesen werden.

Die Umsetzung dieses Prozesses bedeutet, dass die im vorliegenden Dokument geforderten Prozesse der Produktentwicklung, -instandhaltung und -unterstützung des Herstellers die jeweiligen organisatorischen Rollen und das Personal, das für die Durchführung und den Abschluss der Prozesse verantwortlich ist, kennzeichnen. Organisation und Personal können aus der Organisation des Herstellers stammen oder von außen kommen.

ANMERKUNG Eine RACI-Matrix ist ein Beispiel für ein Werkzeug, das zur Erfüllung dieser Anforderungen genutzt werden kann.

5.5 SM-3: Kennzeichnung der Anwendbarkeit

5.5.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem Produkte (oder Teile von Produkten), für die das vorliegende Dokument zutrifft, gekennzeichnet werden.

5.5.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die im Anwendungsbereich als Teil des vorliegenden Dokuments angegebenen Prozesse je nach Notwendigkeit für die entsprechenden Produkte mit der richtigen Detailgenauigkeit angewendet werden.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller Kriterien für die Kennzeichnung besitzt, welche seiner Produkte mit den im vorliegenden Dokument geforderten Prozessen zu entwickeln, instand zu halten und zu unterstützen sind. Es ist vorstellbar, dass ein Hersteller diese Spezifikation auf ausgewählte Produkte anwenden kann und sich dabei auf eine Anzahl von Faktoren stützt, zu denen der Markt gehört, für den ein Produkt vorgesehen ist, und darauf, ob das Produkt die Einbindung und die umfassende Bewertung der IT-Sicherheit erfordert. Als Beispiel haben bestimmte Produkte oder Komponenten unter Umständen kein IT-Sicherheitsumfeld oder bieten einen anonymen Zugriff an und erfordern deshalb keine Einbindung der IT-Sicherheit in das Produkt. Eine Organisation kann die Kriterien auch auf bestimmte Merkmale stützen, die entwickelt werden, um ein Produkt für die Absatzmärkte aufzuwerten, solange die allgemeinen Merkmale nach dem vorliegenden Dokument eingehalten werden. Organisationen dürfen auch Kriterien wie geltende IT-Sicherheitsanforderungen oder IT-Sicherheitsrisiken anwenden.

Diese Anforderungen dürfen auf extern bereitgestellte Komponenten oder kundenspezifische Komponenten von Fremdanbietern angewendet werden. Für weitere Einzelheiten siehe 5.11 und 5.12.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10

EN IEC 62443-4-1:2018

5.6 SM-4: Fachkenntnisse im Hinblick auf die IT-Sicherheit

5.6.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem Schulungs- und Bewertungsprogramme für die IT-Sicherheit festgelegt und bereitgestellt werden, um sicherzustellen, dass das Personal, dem die in 5.4 festgelegten organisatorischen Rollen und Aufgaben zugewiesen wurden, seine Fachkenntnisse im Hinblick auf die IT-Sicherheit für diese Prozesse nachgewiesen hat.

5.6.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass das in sicherheitsbezogene Prozesse eingebundene Personal angemessene Fachkenntnisse für die spezifischen Aufgaben, die ihm zugewiesen wurden, besitzt. Fachkenntnisse können durch Schulung, Erfahrung, Seminare, Konferenzen, Zertifizierungen usw. erlangt worden sein. Dazu gehören technische Fachkenntnisse über Defense-in-Depth-Strategie und zugehörige IT-Sicherheitsverfahren und auch über Verfahren einschließlich bewährter Verfahren, die für die Entwicklung und die Instandhaltung des Produkts erforderlich sind.

Die Umsetzung dieses Prozesses bedeutet, dass das Personal, dem sicherheitsbezogene Prozesse zugewiesen werden, einen Nachweis für seine entsprechenden Qualifizierungen vorweisen kann. Dazu gehören nicht nur Kenntnisse über die IT-Sicherheit, sondern auch über die Anwendung von sicherheitsbezogenen Normen (z. B. Codierungsnormen), Verfahren (z. B. bewährte Verfahren) und Werkzeugen (z. B. statische Analysewerkzeuge). Während eine Schulung der Wahrnehmung der IT-Sicherheit unerlässlich für jede Person ist, die in den gesicherten Produktlebenszyklus eingebunden ist, ist sie im Allgemeinen für Personal, das an der Analyse der IT-Sicherheitsanforderungen, an Entwurfsüberprüfungen usw. beteiligt ist, nicht ausreichend. Die IT-Sicherheitsschulung ist rollenspezifisch und kann formlos oder formal erfolgen. Genauso besitzt das Personal, dem sicherheitsbezogene Prozesse zugewiesen werden, Erfahrungen (z. B. aus früheren Projekten und aus einer Anzahl von Jahren), die an die spezifischen IT-Sicherheitsaufgaben und ihre spezifische Rolle angepasst sind.

5.7 SM-5: Prozesseingrenzung

5.7.1 Anforderung

Es muss ein Prozess, der eine Begründung durch eine dokumentierte IT-Sicherheitsanalyse umfasst, angewendet werden, um die Teile des vorliegenden Dokuments festzulegen, die auf ein ausgewähltes Projekt der Produktentwicklung anwendbar sind. Eine Begründung für die Eingrenzung des Grades der Übereinstimmung eines Projekts mit dem vorliegenden Dokument muss Gegenstand einer Überprüfung und Genehmigung durch Personal mit den angemessenen Fachkenntnissen hinsichtlich IT-Sicherheit sein (siehe 5.6).

5.7.2 Begründung und zusätzliche Leitfäden

Beispiele sind:

- a) Das Produkt umfasst keine Software, sodass für Software geltende Prozessanforderungen nicht zum Anwendungsbereich gehören.
- b) Das Bedrohungsmodell gibt an, dass das Produkt keine externen Schnittstellen oder Quellen mit nicht vertrauenswürdigen Eingaben besitzt (z. B. ein Produkt ohne externe Verbindungen, auf das nur in einem Raum mit hoher physikalischer Sicherheit zugegriffen werden kann). In diesem Fall wäre zum Beispiel die Anforderung für Fuzz-Prüfungen externer Schnittstellen nicht anwendbar.

5.8 SM-6: Integrität von Dateien

5.8.1 Anforderung

Es muss ein Prozess angewendet werden, um einen Mechanismus zum Nachweis der Integrität aller im Produkt eingeschlossenen Skripte, ausführbaren Dateien und anderen wichtigen Dateien bereitzustellen.

5.8.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass ein Produktanwender nachweisen kann, dass ausführbare Dateien, Skripte und andere wichtige Dateien, die vom Hersteller empfangen wurden, nicht geändert wurden. Übliche Verfahren zur Einhaltung dieser Anforderung umfassen kryptographische Hashwerte und digitale Signaturen (die auch einen Herkunftsnachweis bereitstellen).

5.9 SM-7: IT-Sicherheit der Entwicklungsumgebung

5.9.1 Anforderung

Es muss ein Prozess mit Ablaufsteuerungen und technischen Maßnahmen angewendet werden, um das Produkt während der Entwicklung, der Fertigung und der Lieferung zu schützen. Dies umfasst den Schutz des Produkts oder eines Produkt-Updates (Patch) während Entwurf, Implementierung und Freigabe.

5.9.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass das Produkt während des Entwicklungsprozesses in keiner Weise verändert oder offengelegt worden ist, sofern dies nicht gemäß von Leitlinien zulässig ist. Der Verlust der Integrität hinsichtlich eines beliebigen Aspekts der Entwicklungsumgebung (z. B. der Produktentwurf oder die Implementierung, Infrastruktur für Codesignatur und Umgebung für Softwareerstellung) kann die auf den Markt gebrachten Versionen des Produkts ohne Wissen der Organisation oder ihrer Kunden nachteilig beeinflussen. So kann z. B. die Fähigkeit eines Angreifers, Viren in den Binärcode eines Produkts einzufügen, dazu führen, dass sich dieser Virenbefall als Teil des freigegebenen Produkts ausbreitet.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller über Mechanismen verfügt, mit denen die Integrität der Entwurfsdokumente, der Produktimplementierung (z. B. Code und Benutzerhandbuch), der Konfigurationseinstellungen und der privaten Schlüssel für die Signatur von Software-Images geschützt wird. Zum Beispiel kann die Anwendung von Leitlinien und Maßnahmen nach ISO/IEC 27001 [20] und ISO/IEC 27002 [19] die Wahrscheinlichkeit eines nicht autorisierten Zugriffs auf einen Quellcode oder die Verfälschung eines Quellcodes verringern. Außerdem kann die Wahrscheinlichkeit einer unberechtigten Offenlegung von Produktentwürfen und Prüfergebnissen verringert werden, durch die auf den Markt gebrachte Versionen des Produkts gefährdet werden können. Besonders zu schützende Elemente sind Authentifizierer (z. B. Passwörter, Zugriffskontrolllisten, Codesignatur-Zertifikate und Aufzeichnungen des Ausnutzens eines Sicherheitsproblems, die während der Mängelbehandlung gesammelt wurden).

5.10 SM-8: Überwachung privater Schlüssel

5.10.1 Anforderung

Der Hersteller muss über Ablaufsteuerungen und technische Maßnahmen zum Schutz privater Schlüssel für die Codesignatur vor nicht autorisiertem Zugriff oder unberechtigter Abänderung verfügen.

5.10.2 Begründung und zusätzliche Leitfäden

Private Schlüssel sind die Vertrauensanker, und folglich erfordern sie einen zusätzlichen Schutz, um sicherzustellen, dass sie nicht gestohlen oder abgeändert werden.

5.11 SM-9: Anforderungen an die IT-Sicherheit von extern bereitgestellten Komponenten

5.11.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem die IT-Sicherheitsrisiken aller für die Anwendung innerhalb des Produkts von außen bereitgestellten Komponenten gekennzeichnet und behandelt werden.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

5.11.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die IT-Sicherheit der Lieferkette mit angemessenen IT-Sicherheitsverfahren, neuesten IT-Sicherheits-Updates und IT-Sicherheitsimplementierungsleitlinien behandelt wird und der Hersteller reagieren kann, wenn eine Sicherheitslücke aufgedeckt wird. Die IT-Sicherheit der Lieferkette gilt für Komponenten, die in das Produkt eingebettet und dem für das entsprechende Produkt verantwortlichen Entwicklungsteam extern zur Verfügung gestellt werden, die aber die in 5.12 angegebene Definition nicht erfüllen. Die von diesen Fremdkomponenten zur Verfügung gestellte IT-Sicherheit ist unmittelbar mit deren Rolle beim gesicherten Entwurf und bei der Defense-in-Depth-Strategie des Produkts (siehe [Abschnitt 7](#)) verknüpft.

Die Umsetzung dieses Prozesses bedeutet, dass, wenn eine oder mehrere der folgenden Eigenschaften für die Anwendung der Fremdkomponenten im Produkt zutreffen, der Hersteller das Folgende angeben kann:

- den Grad, mit dem die Komponente an das IT-Sicherheitsumfeld des Produkts (siehe [Abschnitt 6](#)) und die Defense-in-Depth-Strategie (siehe [Abschnitt 7](#)) angepasst ist;
- den Grad der Genauigkeit der Implementierung der Komponente (siehe [Abschnitt 8](#));
- den Grad der Verifikation und Validierung der IT-Sicherheit, die vom Hersteller des Produkts oder der Komponente an der Komponente durchgeführt werden (siehe [Abschnitt 9](#));
- wie Benachrichtigungen über sicherheitsbezogene Probleme vom Komponentenhersteller (siehe [Abschnitt 10](#)) und Patches (siehe [Abschnitt 11](#)) zu erhalten und/oder zu überwachen sind;
- die Vollständigkeit der Dokumentation der IT-Sicherheit für die Komponente (siehe [Abschnitt 12](#)); und
- den Grad der aktuellen Unterstützung der Software durch den Hersteller oder durch die Open-Source-Gemeinschaft.

Beispiele für Arbeiten, die einigen Elementen dieser Anforderungen gerecht würden, sind:

- Feststellen bekannter Sicherheitslücken in bestimmten Versionen von Open-Source-Software-Komponenten und Aktualisierung der Version der Open-Source-Software-Komponente auf die Version, die diese Sicherheitslücke behebt;
- Bewerten der Konformität von Lieferanten einer handelsüblichen Komponente (COTS) hinsichtlich des vorliegenden Dokument oder einer vergleichbaren SDL-Norm; und
- Einsetzen von Ausgleichsmechanismen gegen bekannte Sicherheitslücken von handelsüblichen Komponenten (COTS) oder Open-Source-Komponenten (wie statische Code-Analyse).

Es wird empfohlen, eine Bestandsaufnahme der Fremdkomponenten durchzuführen, um die Mängelbehandlung zu unterstützen (siehe [Abschnitt 6](#)).

Zugehörige Anforderungen an die Lieferkette können ISO/IEC 27036-3 [\[21\]](#) entnommen werden.

5.12 SM-10: Kundenspezifische Komponenten von Fremdanbietern

5.12.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass die Prozesse des Entwicklungslebenszyklus für Komponenten von Fremdanbietern mit den Anforderungen des vorliegenden Dokuments übereinstimmen, wenn diese die folgenden Kriterien erfüllen:

- die Komponenten werden speziell für einen einzigen Hersteller für einen besonderen Zweck entwickelt; und
- die Komponenten können sich auf die IT-Sicherheit auswirken.

5.12.2 Begründung und zusätzliche Leitfäden

Diese Anforderungen gelten, wenn ein Hersteller einen Fremdanbieter als Unterauftragnehmer unter Vertrag nimmt, um eine Komponente, die sich auf die IT-Sicherheit auswirken kann, speziell für ihn zu entwickeln. In

der Regel wird mit einem Bedrohungsmodell ermittelt, welche Komponenten Auswirkungen auf die IT-Sicherheit haben.

5.13 SM-11: Bewertung und Behandlung sicherheitsbezogener Probleme

5.13.1 Anforderung

Es muss ein Prozess angewendet werden, um nachzuweisen, dass ein Produkt oder Patch nicht freigegeben wird, bevor seine sicherheitsbezogenen Probleme behandelt und bis zum Abschluss verfolgt wurden (siehe 10.5). Dies schließt Probleme im Zusammenhang mit dem Folgenden ein:

- a) den Anforderungen (siehe Abschnitt 6);
- b) der IT-Sicherheit durch den Entwurf (siehe Abschnitt 7);
- c) der Implementierung (siehe Abschnitt 8);
- d) der Verifikation/Validierung (siehe Abschnitt 9); und
- e) der Mängelbehandlung (siehe Abschnitt 10).

5.13.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass das Produkt nicht mit festgestellten sicherheitsbezogenen Problemen freigegeben wird, die nicht vollständig gelöst wurden und deren Schweregrad nach einem Verwundbarkeitsbewertungssystem wie dem CVSS so berechnet wurde, dass er oberhalb des annehmbaren Restrisikos innerhalb des IT-Sicherheitsumfelds des Produkts liegt.

Die Umsetzung dieses Prozesses bedeutet, dass jegliche sicherheitsbezogenen Probleme, die während der Entwicklung und der Betreuung eines Produkts ermittelt wurden, dokumentiert und behandelt wurden, um das Bestimmen der wirksamen IT-Sicherheit des Produkts vor der Produktfreigabe zu ermöglichen. Dies würde Probleme einschließen, die in allen Phasen, z. B. Entwurfsüberprüfung, Codeüberprüfung, Verifikations- und Validierungsprüfungen, Verwendung von statischen Analysewerkzeugen usw., gefunden wurden.

5.14 SM-12: Prozessverifikation

5.14.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem nachgewiesen wird, dass vor der Produktfreigabe alle anwendbaren von dieser Spezifikation (siehe 5.7) geforderten sicherheitsbezogenen Prozesse abgeschlossen wurden, und Aufzeichnungen zur Dokumentation des Abschlusses jedes Prozesses vorliegen.

5.14.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die Hauptansätze für die IT-Sicherheit durchgeführt werden.

5.15 SM-13: Ständige Verbesserung

5.15.1 Anforderung

Es muss ein Prozess für die ständige Verbesserung des SDL angewendet werden. Dieser Prozess muss die Analyse von IT-Sicherheitsmängeln in Technologien in einer/einem Komponente/Teilsystem/System einschließen, die auf den Markt gelangen.

5.15.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Hersteller die Genauigkeit ihres SDL mit der Zeit verbessern. Neue IT-Sicherheitsbedrohungen werden regelmäßig festgestellt und durch Angreifer ausge-

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10

EN IEC 62443-4-1:2018

nutzt, weshalb es wichtig ist, dass Hersteller dies mittels einer ständigen Verbesserung ihrer SDL ausgleichen.

Ständige Verbesserung ist ein etabliertes und bewährtes Verfahren zur Verbesserung der Produktqualität. Da Probleme der IT-Sicherheit eines Produkts eine Art von Qualitätsproblem darstellen, sind Methoden der ständigen Verbesserung auf einen SDL anwendbar. Für potentielle Maßgrößen in Bezug auf die Effektivität und Verbesserung von SDL siehe [Anhang A](#).

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Vorgehensweise anwendet, um den Prozess und die IT-Sicherheitsmängel zu überprüfen, die periodisch auf den Markt gelangen, und dass diese Vorgehensweise das Erzielen von Verbesserungen des Prozesses als Ergebnis dieser Überprüfungen einschließt.

Einige Beispiele von Aktivitäten, die zu einer Verbesserung eines SDL eines Herstellers beitragen würden, sind in Tabelle 2 angegeben. Letztendlich obliegt es den Herstellern, ihre eigenen Mittel zur ständigen Verbesserung ihrer SDL zu implementieren.

Tabelle 2 – Beispiele für Aktivitäten der ständigen Verbesserung von SDL

Aktivität	Vorteil für SDL/IT-Sicherheit
Verwenden einer anerkannten Datenbank für IT-Sicherheitslücken, um eine Verbesserung des Bedrohungsmodells zu unterstützen. Wenn das Bedrohungsmodell zum Beispiel darauf hinweist, dass das Produkt das TLS-Protokoll für Transportsicherheit verwendet, werden Sicherheitslücken in TLS-Implementierungen überprüft und es wird sichergestellt, dass diese beim Entwurf abgeschwächt werden.	Verbesserung des Bedrohungsmodells, in dem es mit tatsächlichen IT-Sicherheitsproblemen aktuell gehalten wird, die im Einsatz beobachtet werden.
Teilnahme an Konferenzen zu IT-Sicherheit/SDL, die von Fremdanbietern durchgeführt werden, oder Mitarbeit in SDL-Gruppen der Industrie, z. B. OWASP.	Hilft einem Hersteller dabei, hinsichtlich aufkommender Bedrohungen und bester Verfahren für SDL auf dem Laufenden zu bleiben.
Durchführung interner SDL-Konferenzen oder Sitzungen zum Austausch von Fachkenntnissen und bewährten Verfahren in Bezug auf SDL innerhalb der Organisation des Herstellers.	Verbessert die Gesamtkompetenz der Angestellten des Herstellers in Bezug auf SDL und unterstützt sie dabei, hinsichtlich von IT-Sicherheitsbedrohungen und besten Verfahren für SDL auf dem neuesten Stand zu bleiben.
Durchführung einer Analyse der Grundursache in Bezug auf den SDL hinsichtlich IT-Sicherheitslücken, die von Dritten in einem Produkt eines Herstellers gefunden wurden und Festlegung und Ausführung von Abhilfemaßnahmen. Alle SDL-Verfahren sollten bei dieser Analyse erfasst werden.	Eine Analyse der Grundursache und Korrekturmaßnahmen sind bewährte Verfahren zur Verbesserung der Produktqualität. Da IT-Sicherheitsprobleme Qualitätsprobleme sind, funktioniert es auch für einen SDL.
Kombinieren manueller Eindringprüfungen mit Prüfungen mittels automatisierter Werkzeuge, oder Verwendung vergleichbarer Mehrfachwerkzeuge für IT-Sicherheitsprüfungen für SVV-3-Prüfungen von Sicherheitslücken.	Verbessert die Prüfungsabdeckung im Verhältnis zur Anwendung eines einzelnen automatisierten Werkzeugs. Dies wird insbesondere dann nützlich, wenn das vorhandene automatisierte Werkzeug keine neuen Sicherheitslücken findet.
Es sind Fuzzing-Werkzeuge (Fuzzing-Tools) für alle Protokolle zu erzeugen, für die keine Werkzeuge verfügbar sind.	Unterstützt die Vermeidung des Szenarios, in dem ein Angreifer sein eigenes Fuzzing-Werkzeug entwickelt und dieses zum Aufspüren und Ausnutzen von IT-Sicherheitslücken in einem Produkt anwendet.
Schulung und Einsatz spezialisierter Fachleute für Prüfungen von IT-Sicherheit zur Prüfung von Sicherheitslücken, SVV-3.	Da in Bezug auf IT-Sicherheitslücken umfangreiche und stetig zunehmende Fachkenntnisse erforderlich sind, verbessert eine Entwicklung und Nutzung spezialisierter Fachleute die Reichweite einer IT-Sicherheitsprüfung.

6 Ansatz 2 – Spezifikation der IT-Sicherheitsanforderungen

6.1 Zweck

Die in diesem Ansatz festgelegten Prozesse werden zur Dokumentation der Fähigkeiten im Hinblick auf die IT-Sicherheit angewendet, die für ein Produkt zusammen mit dem erwarteten IT-Sicherheitsumfeld des Produkts erforderlich sind. Die Fähigkeiten im Hinblick auf die IT-Sicherheit können Elemente wie die Authentifikation, die Autorisierung, die Verschlüsselung, die Begutachtung einschließen, und weitere Fähigkeiten im Hinblick auf die IT-Sicherheit, die ein Produkt besitzen muss. Das IT-Sicherheitsumfeld des Produkts kann Elemente wie eine physikalische Sicherheitsstufe, den Schutz externer Schnittstellen über eine Firewall usw. umfassen. Weitere Informationen über Anforderungen an die Fähigkeiten im Hinblick auf die IT-Sicherheit können [10] entnommen werden.

Diese IT-Sicherheitsanforderungen dürfen auf der Produktebene definiert werden oder sie dürfen Anforderungen auf der Produktebene ergänzen.

6.2 SR-1: IT-Sicherheitsumfeld des Produkts

6.2.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass das vorgesehene IT-Sicherheitsumfeld des Produkts dokumentiert wird.

6.2.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die Mindestanforderungen der Umgebung und die Annahmen in Bezug auf die Umgebung dokumentiert werden, um eine Sicherheitsstufe zu erreichen, für die das Produkt ausgelegt wurde. Der Zweck der Festlegung dieser Informationen besteht darin, dass die Produktentwickler und die Produktanwender die gleichen Kenntnisse darüber haben, wie der Einsatz des Produkts vorgesehen ist. Damit werden die Entwickler beim Treffen entsprechender Entwurfsentscheidungen und die Nutzer bei der vorgesehenen Anwendung des Produkts unterstützt. Das IT-Sicherheitsumfeld könnte einschließen:

- a) den Ort im Netzwerk;
- b) die physische Sicherheit oder die IT-Sicherheit, die durch die Umgebung, in der das Produkt eingesetzt wird, geboten wird;
- c) eine Trennung (aus Sicht des Netzwerks); und
- d) die mögliche Auswirkung auf die Umgebung (z. B. Verlust von Leben, Verletzung, Produktionsausfall usw.).

Es ist z. B. wichtig, zu dokumentieren, ob eine physische Sicherheit gefordert wird. Wenn keine physische Sicherheit zu erwarten ist, kann das zur Ergänzung einer Anzahl entsprechender Anforderungen führen, wie z. B. das Verbot einer Druckastenkonfiguration am Produkt. Ein weiteres Beispiel ist der Fall, in dem das Produkt erwartungsgemäß mit einer vom Kunden bereitgestellten Firewall geschützt wird, über die es mit dem Anlagennetzwerk verbunden ist, das Produkt selbst aber keine Firewall benötigen würde. Die Dokumentation dieser externen IT-Sicherheitsmerkmale für das Produkt (sein IT-Sicherheitsumfeld) erlaubt den Entwicklern die Entwicklung einer gestaffelten Sicherheitsstrategie, die dieses IT-Sicherheitsumfeld ergänzt, und Prüfern die Validierung und Verifikation der IT-Sicherheit eines Produkts in einer Umgebung ähnlich der, in der der Einsatz vorgesehen ist.

Die Umsetzung dieses Prozesses bedeutet, dass die Einsatzumgebung, in der die Anwendung des Produkts vorgesehen ist, in allen mit dem Einsatz und der Prüfung dieses Produkts verbundenen Prozessen richtig dargestellt und dokumentiert wird.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

6.3 SR-2: Bedrohungsmodell

6.3.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass alle Produkte ein für den aktuellen Entwicklungsumfang des Produkts spezifisches Bedrohungsmodell mit den folgenden Merkmalen (sofern anwendbar) aufweisen müssen:

- a) einen ordnungsgemäßen Fluss der kategorisierten Informationen im gesamten System;
- b) Vertrauensgrenzen;
- c) Prozesse;
- d) Datenspeicher;
- e) Wechselwirkungen mit externen Instanzen;
- f) interne und externe Kommunikationsprotokolle, die im Produkt implementiert sind;
- g) von außen zugängliche physische Anschlüsse einschließlich Debug-Anschlüsse;
- h) Leiterplattenanschlüsse wie JTAG-Anschlüsse oder Debug-Anschlussleisten, die zum Angriff auf die Hardware genutzt werden können;
- i) mögliche Angriffsvektoren einschließlich von Angriffen auf die Hardware, soweit anwendbar;
- j) mögliche Bedrohungen und deren Schweregrad nach einer Festlegung durch ein Verwundbarkeitsbewertungssystem (z. B. CVSS);
- k) Abschwächungsmaßnahmen und/oder Behandlung jeder Bedrohung;
- l) ermittelte sicherheitsbezogene Probleme; und
- m) äußere Abhängigkeiten in Form von Treibern oder Fremdanwendungen (nicht vom Hersteller entwickelter Code), die mit der Anwendung verknüpft werden.

Das Bedrohungsmodell muss durch das Entwicklungsteam überprüft und verifiziert werden, um sicherzustellen, dass es ordnungsgemäß ist und verstanden wird.

Das Bedrohungsmodell muss für freigegebene Produkte periodisch (mindestens einmal im Jahr) überprüft werden, und aktualisiert werden, wenn dies als Antwort auf das Auftreten neuer Bedrohungen für das Produkt erforderlich ist, auch wenn sich der Entwurf nicht ändert.

Sämtliche Probleme, die im Bedrohungsmodell gekennzeichnet werden, müssen nach den Festlegungen in [10.4](#) und [10.5](#) behandelt werden.

6.3.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass IT-Sicherheitsbedrohungen für das Produkt vom Projektteam des Produkts nach der Defense-in-Depth-Strategie gekennzeichnet, validiert, gepflegt, dokumentiert, behandelt und geprüft werden.

Die Umsetzung dieses Prozesses bedeutet, dass während des gesamten Produktlebenszyklus ein Bedrohungsmodell für das Produkt definiert und unterhalten wird (z. B. infolge wechselnder Bedrohungen oder Updates der gestaffelten Sicherheitsstrategie), das Bedrohungen kennzeichnet und beschreibt, die im Sicherheitsumfeld des Produkts auftreten können und gegen die sich das Produkt erwartungsgemäß selbst verteidigen muss.

Äußere Abhängigkeiten sind externe Komponenten oder Systeme, von denen die IT-Sicherheit des Produkts abhängt. Die physikalische Sicherheit eines Produkts kann beispielsweise von der Energieversorgung abhängen. Die IT-Sicherheit eines Produkts kann von der Sitzungsverwaltung eines Webserverns abhängen. Bei diesen Beispielen kann ein Versagen der äußeren Abhängigkeit zu einer IT-Sicherheitslücke im Produkt führen, so dass Abschwächungsmaßnahmen ergriffen werden müssen, um die Möglichkeiten eines solchen Versagens auf ein Mindestmaß zu verringern. Für das Beispiel der Energieversorgung kann diese Abschwächungsmaßnahme in der Installation einer unterbrechungsfreien Stromversorgung (USV) bestehen. Für das Beispiel des Webserverns sollte die IT-Sicherheit bei der Auswahl eines Webserverns berücksichtigt

werden und wenn kein gesicherter Webserver gefunden werden kann, müssen andere Kompensationsmaßnahmen in Betracht gezogen werden.

Ein Fremdcode ist eine äußere Abhängigkeit, die erhebliche Herausforderungen für die Bestimmung darstellen kann, wo die Bedrohungen auftreten können. Bei einer tiefen Einbettung gibt es möglicherweise keinen Zugriff auf diesen/von diesem Code, der eine Vertrauensgrenze überschreitet. Wenn eine Überschreitung der Vertrauensgrenze stattfindet, ist unter Umständen eine genauere Überprüfung des Fremdcodes erforderlich.

6.4 SR-3: IT-Sicherheitsanforderungen für das Produkt

6.4.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem sichergestellt wird, dass IT-Sicherheitsanforderungen für das zu entwickelnde Produkt/Merkmal dokumentiert werden einschließlich der Anforderungen an die Fähigkeiten im Hinblick auf die IT-Sicherheit bei Installation, Betrieb, Instandhaltung und Außerbetriebnahme.

6.4.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass produktspezifische IT-Sicherheitsanforderungen festgelegt werden. Dazu gehören sowohl technische IT-Sicherheitsanforderungen (z. B. Passwortkomplexität) als auch wirtschaftlich orientierte IT-Sicherheitsanforderungen (z. B. schützenswerte Daten, Benutzerrechte und Aufgabentrennung).

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller alle IT-Sicherheitsanforderungen für das Produkt festlegt und dokumentiert, die während des Lebenszyklus des Produkts gelten, einschließlich von:

- a) IT-Sicherheitsrechten, die für die Installation, den Betrieb und die Instandhaltung des Produkts erforderlich sind;
- b) IT-Sicherheitsoptionen einschließlich der Aufhebung voreingestellter Passwörter, die für die Installation, die Konfiguration, den Betrieb und die Instandhaltung des Produkts genutzt werden; und
- c) IT-Sicherheitsbetrachtungen/-aktionen im Zusammenhang mit der Außerbetriebnahme des Produkts (z. B. Löschen schützenswerter Daten).

ANMERKUNG Für unterschiedliche erreichbare Security-Level (SL-C 1 bis SL-C 4) sind in IEC 62443-3-3 und IEC 62443-4-2 [11] die Anforderungen an Fähigkeiten im Hinblick auf die IT-Sicherheit für Automatisierungssysteme beziehungsweise Komponenten festgelegt. Diese Fähigkeiten im Hinblick auf die IT-Sicherheit werden dann als IT-Sicherheitsanforderungen für das Produkt in diejenigen Produkte eingebunden, die diese Fähigkeiten besitzen müssen.

6.5 SR-4: Anforderungen an das IT-Sicherheitsumfeld des Produkts

6.5.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem sichergestellt wird, dass IT-Sicherheitsanforderungen folgende Informationen enthalten:

- a) den Anwendungsbereich und die Grenzen der Komponente oder des Systems im Allgemeinen sowohl physisch als auch logisch; und
- b) den erreichbaren Security-Level (SL-C) des Produkts.

6.5.2 Begründung und zusätzliche Leitfäden

Wenn das Produkt darauf ausgerichtet ist, eine bestimmte Fähigkeit im Hinblick auf die IT-Sicherheit zu erfüllen, muss diese unbedingt als eine Anforderung dokumentiert werden, weil dies bedeutet, dass bestimmte Fähigkeiten im Hinblick auf die IT-Sicherheit in das Produkt integriert werden müssen. Es ist zu beachten, dass erreichbare Security-Level und geforderte Fähigkeiten im Hinblick auf die IT-Sicherheit für Produkte in IEC 62443-4-2 [11] und IEC 62443-3-3 [10] festgelegt sind.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

6.6 SR-5: Überblick über IT-Sicherheitsanforderungen

6.6.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass IT-Sicherheitsanforderungen überprüft, gegebenenfalls aktualisiert und bestätigt werden, um deren Nachvollziehbarkeit, Gültigkeit, Übereinstimmung mit dem Bedrohungsmodell (erörtert in [6.3](#)) und Nachweisfähigkeit sicherzustellen. Jede der folgenden vertretenen Fachrichtungen muss in den Prozess einbezogen werden: Personal darf mehr als einer Fachrichtung zugewiesen werden, mit Ausnahme von Prüfern, welche unabhängig bleiben müssen.

- a) Entwickler (diejenigen, die die Anforderungen umsetzen werden);
- b) Prüfer (diejenigen, die nachweisen werden, dass die Anforderungen erfüllt worden sind);
- c) Kundenvertreter (wie Verkauf, Marketing, Produktmanagement oder Kundendienst), und
- d) Sicherheitsberater.

6.6.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass IT-Sicherheitsanforderungen gelten und verständlich sowie prüfbar (oder anders nachweisbar) sind.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller alle IT-Sicherheitsanforderungen überprüft und diejenigen überarbeitet/streicht, die ungültig oder nicht prüfbar/nachweisbar sind.

7 Ansatz 3 – IT-Sicherheit durch den Entwurf

7.1 Zweck

Mit den in diesem Ansatz festgelegten Prozessen wird sichergestellt, dass das Produkt durch den Entwurf sicher ist und über ein gestaffeltes Sicherheitskonzept verfügt. Ein gestaffeltes Sicherheitskonzept bietet eine oder mehrere IT-Sicherheitsschichten, um IT-Sicherheitsbedrohungen entgegenzuwirken. Jede Schicht der gestaffelten Sicherheitsstrategie ist so ausgelegt, dass sie die Schutzobjekte gegen Angriffe schützt, falls alle anderen Schichten überwunden worden sind.

Die für diesen Ansatz erforderlichen Prozesse müssen auf alle Schichten des Produktentwurfs von der Entwurfsplanung bis zum genauen Entwurf und auf alle Ebenen des Produktentwurfs von der Gesamtarchitektur bis zum Entwurf einzelner Komponenten angewendet werden.

7.2 SD-1: Grundsätze für einen gesicherten Entwurf

7.2.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem ein gesicherter Entwurf entwickelt und dokumentiert wird, der jede Schnittstelle des Produkts einschließlich physikalischer und logischer Schnittstellen kennzeichnet und beschreibt, um das Folgende anzugeben:

- a) einen Hinweis, ob die Schnittstelle von außen (von anderen Produkten) oder von innen (von anderen Komponenten des Produkts) zugänglich ist oder ob beides zutrifft;
- b) IT-Sicherheitsauswirkungen des IT-Sicherheitsumfelds des Produkts (siehe [Abschnitt 6](#)) auf die externe Schnittstelle;
- c) mögliche Benutzer der Schnittstelle und die Schutzobjekte, auf die darüber zugegriffen werden kann (direkt oder indirekt);
- d) eine Bestimmung, ob der Zugriff auf die Schnittstelle eine Vertrauensgrenze überschreitet;
- e) IT-Sicherheitsbetrachtungen, Annahmen und/oder Bedingungen im Zusammenhang mit der Nutzung der Schnittstelle innerhalb des IT-Sicherheitsumfelds des Produkts einschließlich zutreffender Bedrohungen;

- f) die IT-Sicherheitsrollen, Berechtigungen/Rechte und Zugriffsberechtigungen, die für die Nutzung der Schnittstelle und für den Zugriff auf die vorgenannt in c) angegebenen Schutzobjekte erforderlich sind;
- g) die Fähigkeiten im Hinblick auf die IT-Sicherheit und/oder Kompensationsmechanismen zum Schutz der Schnittstelle und der vorgenannt in c) festgelegten Schutzobjekte einschließlich der Validierung sowohl von Eingaben und Ausgaben und der Fehlerbehandlung;
- h) die Nutzung von Fremdprodukten zur Implementierung der Schnittstelle und deren Fähigkeiten im Hinblick auf die IT-Sicherheit;
- i) eine Dokumentation, die beschreibt, wie die Schnittstelle anzuwenden ist, wenn sie von außen zugänglich ist; und
- j) eine Beschreibung, wie der Entwurf die im Bedrohungsmodell gekennzeichneten Bedrohungen abschwächt.

7.2.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die IT-Sicherheit für den Zugriff auf Schutzobjekte aus der Sicht der externen und internen Schnittstellen des Produkts, über die Angriffe ausgeführt werden können, umfassend behandelt wird.

Die Umsetzung dieses Prozesses bedeutet, dass Schnittstellen des Produkts gekennzeichnet werden und durch die Wechselwirkungen, die über die Schnittstellen stattfinden (z. B. Datenströme und Kontrollflüsse), die IT-Sicherheitsmechanismen, die für ihren Schutz entworfen werden, und die Schutzobjekte, die bei einem unzureichenden Schutz gefährdet werden können, beschrieben werden. Zu Schnittstellen gehören physikalische und drahtlose Verbindungen mit Netzwerken (z. B. Ethernet) und Geräten (z. B. Tastaturen, Bildschirme und USB-/CD-/DVD-Medien). Logische Schnittstellen unterstützen Datenkontrollflüsse (z. B. Anwendungsbenachrichtigungen) zwischen Produktkomponenten und umfassen Mechanismen wie Anwendungsprogrammierschnittstellen (z. B. strukturierte Abfragesprache (SQL)) und Kommunikationsprotokolle (z. B. Übertragungssteuerungsprotokoll (TCP)). Schutzmechanismen sind unter anderem allgemeine Härtungsfähigkeiten (z. B. Einstellungen von IT-Sicherheitsleitlinien), Benutzerzugriffskontrolle (z. B. Kontenverwaltung), und Erkennung und Meldung von Ereignissen im Hinblick auf die IT-Sicherheit.

Die Betrachtung der Schnittstellen innerhalb des Rahmens, der durch das IT-Sicherheitsumfeld des Produkts geboten wird, erlaubt eine Ausrichtung des gesicherten Entwurfs auf die spezifische Umgebung, in der das Produkt erwartungsgemäß betrieben wird, einschließlich des Schutzes, der durch das IT-Sicherheitsumfeld des Produkts geboten wird, sowie der daraus resultierenden Sicherheitslücken (z. B. wo Angriffe möglich sind). Für eine innere Komponente des Entwurfs wird der Begriff des IT-Sicherheitsumfelds des Produkts um das IT-Sicherheitsumfeld erweitert, das durch Produktkomponenten in der Umgebung geboten wird. Zum IT-Sicherheitsumfeld eines Anwendungsprogramms, das auf einer Workstation läuft, die Teil eines Produkts eines industriellen Automatisierungssystems ist, gehören z. B. das (die) Netzwerk(e), an das (die) die Workstation angeschlossen ist, und die Softwareumgebung der Workstation, in der die Anwendung läuft.

Die Kennzeichnung von Bedrohungen, Nutzern, Schutzobjekten und Vertrauensgrenzen im Zusammenhang mit Schnittstellen legt fest, wer die Schnittstellen erwartungsgemäß nutzt, und gibt an, wo Bedrohungen und unbekannte Subjekte möglicherweise Zugriff auf die Schnittstelle und die Schutzobjekte, auf die über die Schnittstelle zugegriffen werden kann, erlangen können. Damit kann gegebenenfalls die Anzahl der Schnittstellen verringert werden und für die verbleibenden Schnittstellen und die Schutzobjekte, auf die darüber zugegriffen werden kann, können angemessene Schutzmaßnahmen ergriffen werden. Die Kennzeichnung von Vertrauensgrenzen unterstützt außerdem die zukünftige Definition von Zonen und Conduits (siehe IEC 62443-3-2 [9]) und bildet damit eine Hauptkomponente bei der Definition der IT-Sicherheitsarchitektur des Produkts. Beispiele für Datenschutzobjekte (Ressourcen) sind:

- a) Datenbanken und Datenbanktabellen;
- b) Konfigurationsdateien;
- c) Speicher für kryptographische Schlüssel;
- d) Zugriffskontrolllisten (ACL);
- e) Registrierungsschlüssel;
- f) Webseiten (statisch und dynamisch);

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

- g) Auditprotokolle;
- h) Netzwerkdaten/Netzwerkmedien;
- i) Kommunikation zwischen Prozessen (IPC; en: inter-process communications), Dienste und Ressourcen des Fernprozeduraufrufs (RPC; en: remote procedure call);
- j) alle anderen Dateien und Verzeichnisse; und
- k) alle anderen Speicherressourcen.

Auf der Grundlage der Analyse der IT-Sicherheitsanforderungen für das Produkt, des IT-Sicherheitsumfelds des Produkts und der Berücksichtigung der Vertrauensgrenzen kann der für Schnittstellen zu entwickelnde Entwurf die Definition der Benutzerrollen, Benutzerrechte und Benutzerzugriffsberechtigungen, die zur Nutzung der Schnittstellen erforderlich sind, sowie spezifische Fähigkeiten im Hinblick auf die IT-Sicherheit (z. B. Authentifikation, Verschlüsselung und Protokollierung), die zusätzliche Schutzmaßnahmen bieten, umfassen. Als Teil des Entwurfs der Defense-in-Depth-Strategie wird die erwartete Nutzung von Kompensationsmechanismen und von Hardware- oder Software-Fremdkomponenten die Bewertung der Angemessenheit der Defense-in-Depth-Strategie unterstützen (siehe 7.4).

Die Erstellung einer Dokumentation für die Anwendung von außen zugänglicher Schnittstellen (z. B. durch Nutzer und Dritte) verringert letztendlich das Missbrauchspotential.

7.3 SD-2: Entwurf eines Defense-in-Depth-Konzepts

7.3.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem mehrere IT-Sicherheitsschichten eingefügt werden, wobei ein risikobasierter Ansatz verwendet wird, der auf dem Bedrohungsmodell beruht. Dieser Prozess muss für die Zuweisung von Verantwortlichkeiten zu jeder IT-Sicherheitsschicht angewendet werden.

ANMERKUNG 1 Jede Schicht bietet zusätzliche Sicherheitsmechanismen.

ANMERKUNG 2 Es ist für jede beliebige Schicht möglich, dass sie kompromittiert wird, und folglich werden Grundsätze für einen gesicherten Entwurf (siehe 7.2) für jede Schicht angewendet.

ANMERKUNG 3 Das Ziel ist die Verringerung der Angriffsfläche der nachfolgenden Schichten.

7.3.2 Begründung und zusätzliche Leitfäden

Ein TCP/IP-Stapel könnte z. B. eine Prüfung auf ungültige Pakete durchführen, ein HTTP-Server könnte die Eingabe authentifizieren und anschließend könnte eine andere Schicht validieren, dass die Eingabe- und Ereignisprotokolle für administrative Änderungen erstellt werden. Jede Schicht bietet einen weiteren Schutzmechanismus, besitzt eine Verantwortlichkeit und verringert die Angriffsfläche für die nächste Schicht. Jede Schicht nimmt an, dass die ihr vorgelagerte Schicht überwunden werden kann.

7.4 SD-3: Entwurfsprüfung der IT-Sicherheit

7.4.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem Entwurfsüberprüfungen durchgeführt werden, um sicherheitsbezogene Probleme im Zusammenhang mit jeder grundlegenden Überarbeitung des gesicherten Entwurfs zu kennzeichnen, zu beschreiben und bis zum Abschluss zu verfolgen, unter anderem einschließlich:

- a) der Kennzeichnung von IT-Sicherheitsanforderungen (siehe [Abschnitt 6](#)), die von der Implementierung nicht ausreichend behandelt wurden;

ANMERKUNG 1 Die Zuweisung von Anforderungen einschließlich von IT-Sicherheitsanforderungen ist Teil typischer Entwurfsprozesse.

- b) von Bedrohungen und deren Fähigkeit, Produktschnittstellen, Vertrauensgrenzen und Schutzobjekte auszunutzen (siehe 7.2); und
- c) der Kennzeichnung bewährter Entwurfsverfahren (siehe 7.5), die nicht eingehalten wurden (z. B. Nichtanwendung der Grundsätze der minimal erforderlichen Rechte).

ANMERKUNG 2 Die Beschreibung von Bedrohungen und deren Fähigkeit der Ausnutzung von Schnittstellen wird häufig als Bedrohungsmodellierung bezeichnet.

7.4.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass der gesicherte Entwurf die Anforderungen und Bedrohungen (siehe Abschnitt 6), die für das Produkt definiert sind, behandelt und bewährten Entwurfsverfahren (siehe 7.5) gefolgt wurde. Alle festgestellten sicherheitsbezogenen Probleme sind nach den Festlegungen in 7.4 und 10.5 zu dokumentieren und durch den Prozess hindurch zu verfolgen.

Die Umsetzung dieses Prozesses bedeutet, dass jede Version des Entwurfs überprüft wird, um festzustellen:

- a) ob von der gestaffelten Sicherheitsstrategie irgendwelche IT-Sicherheitsanforderungen für das Produkt nicht ausreichend behandelt worden sind; und
- b) ob es Bedrohungsvektoren gibt (Pfade, denen Bedrohungen folgen), die die gestaffelten Sicherheitsstrategie umgehen oder die Defense-in-Depth-Strategie anders verletzen können.

In jedem Fall muss das Bedrohungsmodell aktualisiert werden, um sicherheitsbezogene Probleme wiederzugeben, die infolge des Überprüfungsprozesses festgestellt wurden.

7.5 SD-4: Bewährte Verfahren des gesicherten Entwurfs

7.5.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass bewährte Verfahren für einen gesicherten Entwurf dokumentiert und im Entwurfsprozess angewendet werden. Diese Verfahren müssen periodisch überprüft und aktualisiert werden. Verfahren für einen gesicherten Entwurf umfassen unter anderem:

- a) minimal erforderliche Rechte (Rechte werden nur Nutzern/Software gewährt, die für die Ausführung der vorgesehenen Operationen erforderlich sind/ist);
- b) gegebenenfalls die Anwendung bewährter Sicherheitskomponenten/-entwürfe;
- c) die Wirtschaftlichkeit des Mechanismus (Anstreben eines einfachen Entwurfs);
- d) die Nutzung gesicherter Entwurfsmuster;
- e) die Verringerung der Angriffsfläche;
- f) die Dokumentation aller Vertrauensgrenzen als Teil des Entwurfs, und
- g) das Entfernen von Debug-Anschlüssen, Debug-Anschlussleisten und Leiterbahnen auf Leiterplatten, die bei der Entwicklung verwendet wurden, von der Fertigungshardware oder Dokumentation ihres Vorhandenseins und der Notwendigkeit ihres Schutzes gegen unberechtigten Zugriff.

7.5.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass den Entwicklern Leitfäden vorgegeben werden, die eine Unterstützung bei der Vermeidung allgemeiner Fallen bei der Entwicklung bieten, die zu späteren IT-Sicherheitsproblemen führen können.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Liste bewährter IT-Sicherheitsverfahren besitzt, die bei der Entwicklung des gesicherten Entwurfs für das Produkt geführt und befolgt wird. Diese bewährten Verfahren sollten auf bewährten Verfahren der IT-Sicherheit für den in Entwicklung befindlichen Produkttyp beruhen, die in der Industrie allgemein anerkannt sind. Es obliegt voll und ganz dem Hersteller zu bestimmen, welche Verfahren (Ansätze) sie für ihre Entwurfsverfahren als am besten geeignet betrachten.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

Diese Verfahren werden infolge sowohl von Änderungen der industriellen Praxis als auch der Nutzung gewonnener Erkenntnisse des Herstellers auf dem neusten Stand gehalten.

Es ist zu beachten, dass diese Verfahren (Ansätze) sowohl für den Hardware- als auch den Softwareentwurf anwendbar sind.

8 Ansatz 4 – Gesicherte Implementierung

8.1 Zweck

Die von diesem Ansatz festgelegten Prozesse werden genutzt, um sicherzustellen, dass die Produktmerkmale auf sichere Weise implementiert werden.

8.2 Anwendbarkeit

Anforderungen in diesem Ansatz gelten sowohl für Hardware- als auch für Softwarekomponenten im Produkt, mit Ausnahme von extern bereitgestellten Komponenten. Für extern bereitgestellte Komponenten gilt stattdessen die Anforderung 5.11.

8.3 SI-1: Überprüfung der gesicherten Implementierung

8.3.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass Überprüfungen der Implementierung durchgeführt werden, um sicherheitsbezogene Probleme im Zusammenhang mit der Implementierung des gesicherten Entwurfs zu kennzeichnen, zu beschreiben und bis zum Abschluss zu verfolgen; dazu gehören:

- a) die Kennzeichnung von IT-Sicherheitsanforderungen (siehe [Abschnitt 6](#)), die von der Implementierung nicht ausreichend behandelt wurden;

ANMERKUNG Die Zuweisung von Anforderungen einschließlich von IT-Sicherheitsanforderungen ist Teil typischer Entwurfsprozesse.

- b) die Kennzeichnung von Codierungsnormen für IT-Sicherheit (siehe [8.4](#)), die nicht eingehalten wurden (z. B. die Nutzung verbotener Funktionen oder die Nichtanwendung des Grundsatzes der minimal erforderlichen Rechte);
- c) eine statische Codeanalyse (SCA) für den Quellcode, um unter Anwendung der Codierungsnorm für IT-Sicherheit für die unterstützte Programmiersprache Fehler der Sicherheitscodierung, z. B. einen Pufferüberlauf, eine Null-Pointer-Dereferenzierung usw., zu ermitteln. Falls verfügbar, muss die SCA mit einem für die verwendete Sprache verfügbaren Werkzeug durchgeführt werden. Zusätzlich muss eine statische Codeanalyse an allen Quellcodeänderungen einschließlich neuer Quellcodes durchgeführt werden;
- d) die Überprüfung der Implementierung und deren Rückverfolgbarkeit auf die Fähigkeiten im Hinblick auf die IT-Sicherheit, die zur Unterstützung des gesicherten Entwurfs festgelegt sind (siehe [Abschnitt 7](#)); und
- e) die Untersuchung von Bedrohungen und deren Fähigkeit zur Ausnutzung von Implementierungsschnittstellen, Vertrauensgrenzen und Schutzobjekten (siehe [7.2](#) und [7.3](#)).

8.3.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die Implementierung den gesicherten Entwurf und die zugehörigen IT-Sicherheitsanforderungen ordnungsgemäß umsetzt und bewährte Implementierungsverfahren einhält.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine umfassende Menge von IT-Sicherheitsüberprüfungen der Implementierung und des Entwurfs durchführt. Für verschiedene Ziele werden in der Regel verschiedene Arten der Überprüfung genutzt. Manuelle Überprüfungen werden gewöhnlich z. B. für den implementierten Entwurf durchgeführt, um nachzuweisen, dass die Anforderungen erfüllt werden und die Implementierung ausreichend gegen erwartete Bedrohungen geschützt ist. Darüber hinaus kann mit

manuellen Überprüfungen des Quellcodes dieser auf die Einhaltung bewährter Verfahren untersucht werden (siehe 8.4) und mit der automatisierten statischen Quellcodeanalyse dürfen Anomalien einschließlich von IT-Sicherheitslücken im Code sowie die Nichteinhaltung vorgegebener Programmierungsvorschriften gekennzeichnet werden.

8.4 SI-2: Codierungsnormen für IT-Sicherheit

8.4.1 Anforderung

Die Implementierungsprozesse müssen unter Einbeziehung von Codierungsnormen für IT-Sicherheit durchgeführt werden, die periodisch überprüft und aktualisiert werden und mindestens das Folgende umfassen:

- Vermeidung von Implementierungskonstrukten, die möglicherweise ausgenutzt werden können – Entwurfsmuster für Implementierungen, die bekanntermaßen IT-Sicherheitslücken aufweisen;
- Vermeidung von verbotenen Funktionen und von Codierungskonstrukten/Entwurfsmustern – Softwarefunktionen und Entwurfsmuster, die nicht angewendet werden sollten, weil sie bekannte IT-Sicherheitslücken besitzen;
- Anwendung automatisierter Werkzeuge und Einstellungen (z. B. für statische Analysewerkzeuge);
- gesicherte Codierungsverfahren;
- Validierung aller Eingaben, die Vertrauensgrenzen überschreiten;
- Fehlerbehandlung.

8.4.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Entwicklern Leitfäden vorgegeben werden, die eine Unterstützung bei der Vermeidung allgemeiner Fallen bei der Implementierung bieten, die zu späteren Sicherheitsproblemen führen können.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Liste bewährter IT-Sicherheitsverfahren besitzt, die bei der Implementierung eines Produkts geführt und befolgt wird. Diese bewährten Verfahren sollten auf bewährten Verfahren der IT-Sicherheit für den in Entwicklung befindlichen Produkttyp beruhen, die in der Industrie allgemein anerkannt sind. Es obliegt voll und ganz dem Hersteller zu bestimmen, welche Verfahren (Ansätze) sie für ihre Entwurfs- und Codierungsnorm als am besten geeignet betrachten. Diese Verfahren werden infolge sowohl von Änderungen der industriellen Praxis als auch der Nutzung gewonnener Erkenntnisse des Herstellers auf dem neuesten Stand gehalten.

9 Ansatz 5 – Verifikations- und Validierungsprüfungen der IT-Sicherheit

9.1 Zweck

Die von diesem Ansatz festgelegten Prozesse werden genutzt, um die erforderlichen IT-Sicherheitsprüfungen zu dokumentieren, um sicherzustellen, dass alle IT-Sicherheitsanforderungen für das Produkt erfüllt worden sind und die IT-Sicherheit des Produkts aufrechterhalten wird, wenn das Produkt in seinem IT-Sicherheitsumfeld eingesetzt wird und so konfiguriert ist, dass seine Defense-in-Depth-Strategie greift.

IT-Sicherheitsprüfungen können je nach Art der Prüfung und des vom Anbieter verwendeten Entwicklungsmodells zu verschiedenen Zeiten von verschiedenen Personen während des gesicherten Entwicklungslebenszyklus durchgeführt werden. Fuzz-Prüfungen können z. B. während der Softwareentwicklung vom Softwareentwicklungsteam und später im Entwicklungslebenszyklus vom Prüftteam durchgeführt werden.

Nicht durch Prüfungen aufgedeckte Probleme werden gemäß „Ansatz 6 – Behandlung von Mängeln der IT-Sicherheit“ behandelt.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

9.2 SVV-1: Prüfung der IT-Sicherheitsanforderungen

9.2.1 Anforderung

Es muss ein Prozess angewendet werden, um nachzuweisen, dass die IT-Sicherheitsfunktionen des Produkts den IT-Sicherheitsanforderungen entsprechen und das Produkt Fehlerszenarien und ungültige Eingaben ordnungsgemäß verarbeitet. Zu den Arten der Prüfung müssen gehören:

- a) funktionale Prüfungen der IT-Sicherheitsanforderungen;
- b) Leistungs und Skalierungsprüfungen; und
- c) Grenzwert-/Randbedingungsprüfungen, Beanspruchungsprüfungen und Prüfungen mit verfälschten oder unerwarteten Eingaben, die nicht speziell auf die IT-Sicherheit abzielen.

9.2.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass das Produkt die festgelegten IT-Sicherheitsanforderungen erfüllt (siehe [Abschnitt 6](#)).

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller während der Prüfung nachweist, dass das Produkt die dokumentierten IT-Sicherheitsanforderungen erfüllt.

Beispiele dieser Typen von Funktionalitäten im Umfang für Anforderungen der IT-Sicherheit umfassen:

- a) allgemeine Fähigkeiten im Hinblick auf die IT-Sicherheit (Merkmale);
- b) API (Anwendungsprogrammierschnittstelle);
- c) Befugnisübertragung für Berechtigungen;
- d) Funktionalität für Manipulationserkennung und Integrität;
- e) Verifikation mit signierten Bildern; und
- f) sichere Speicherung vertraulicher Informationen.

9.3 SVV-2: Prüfung der Bedrohungsabschwächung

9.3.1 Anforderung

Es muss ein Prozess zur Prüfung der Wirksamkeit der Abschwächung der Bedrohungen angewendet werden, die im Bedrohungsmodell gekennzeichnet und validiert sind. Aktivitäten müssen das Folgende umfassen:

- a) Erstellen und Ausführen von Plänen, um sicherzustellen, dass jede für eine spezifische Bedrohung umgesetzte Abschwächungsmaßnahme ausreichend geprüft worden ist, um sicherzustellen, dass die Abschwächungsmaßnahme wie vorgesehen greift, und
- b) Erstellen und Ausführen von Plänen für den Versuch jeder Abschwächung entgegenzuwirken.

9.3.2 Begründung und zusätzliche Leitfäden

Als Teil dieses Ansatzes wird die Wirksamkeit der Abschwächungsmaßnahmen für Bedrohungen, die vom Bedrohungsmodell gekennzeichnet werden, geprüft. Beispiele für die Prüfung der Bedrohungsabschwächung sind Versuche, die gekennzeichneten Abschwächungsmaßnahmen durch Vortäuschung, Manipulation, Nichtanerkennung, Offenlegung von Informationen, Dienstleistungsverhinderung, Rechteausweitung (STRIDE-Modell) zu überwinden. Wenn STRIDE z. B. Authentifikation als eine Abschwächungsmaßnahme für die Bedrohung durch Vortäuschen bestimmt hat, würden Prüfungen auf die Umgehung der Authentifikation ausgerichtet werden.

Wenn eine Defense-in-Depth-Strategie als eine Abschwächungsmaßnahme angewendet wird, muss die Wirksamkeit jeder Schicht geprüft werden. Wenn das Produkt z. B. die Kombination von Authentifikation,

Autorisierung und Audit-Protokollen als eine Defense-in-Depth-Strategie nutzt, um einer Manipulation entgegenzuwirken, dann wird jede Schicht auf ihren Beitrag zu dieser Abschwächungsstrategie geprüft.

Dieser Prozess ist erforderlich, um sicherzustellen, dass die Defense-in-Depth-Strategie des Produkts und die Strategien und Fähigkeiten zur Abschwächung der Bedrohungen wirksam sind.

9.4 SVV-3: Prüfung von Sicherheitslücken

9.4.1 Anforderung

Es muss ein Prozess zur Durchführung von Prüfungen angewendet werden, der auf die Kennzeichnung und Beschreibung möglicher Sicherheitslücken im Produkt ausgerichtet ist. Die Prüfung bekannter Sicherheitslücken muss sich mindestens auf die neuesten Inhalte einer eingeführten, von der Industrie anerkannten, öffentlichen Quelle bekannter Sicherheitslücken stützen. Prüfungen müssen das Folgende umfassen:

- a) die Prüfung von Missbrauchsfällen oder Prüfungen mit verfälschten oder unerwarteten Eingaben, die auf die Aufdeckung von IT-Sicherheitsproblemen ausgerichtet sind. Dazu müssen manuelle oder automatisierte Prüfungen von Missbrauchsfällen und spezielle Arten der Prüfung von Missbrauchsfällen aller externen Schnittstellen und Protokolle gehören, für die Werkzeuge vorhanden sind. Beispiele dafür sind Fuzz-Prüfungen und Prüfungen des Netzwerkverkehrs und der Netzwerkkapazität;
- b) eine Analyse der Angriffsfläche zur Bestimmung aller Eintritts- und Austrittswege in ein und aus einem System, allgemeiner Sicherheitslücken einschließlich unter anderem schwache ACL, offener Anschlüsse und Dienste mit erweiterten Berechtigungen;
- c) ein Black-Box-Scan auf bekannte Sicherheitslücken, der auf die Feststellung bekannter Sicherheitslücken in Produkthardware-, Host- oder Softwarekomponenten ausgerichtet ist; Das kann z. B. ein netzwerkbasierter Scan auf bekannte Sicherheitslücken sein;
- d) für kompilierte Software eine Analyse der Softwarezusammensetzung an allen binär ausführbaren Dateien einschließlich eingebetteter Firmware, die vom Hersteller zur Installation für ein Produkt geliefert wird. Diese Analyse muss wenigstens folgende Arten von Problemen feststellen:
 - 1) bekannte Sicherheitslücken in den Softwarekomponenten des Produkts;
 - 2) eine Verknüpfung mit verwundbaren Bibliotheken;
 - 3) Verletzungen von IT-Sicherheitsvorschriften;
 - 4) Compiler-Einstellungen, die zu Sicherheitslücken führen können;
- e) eine Prüfung der dynamischen Ressourcenverwaltung für die Laufzeit, die Mängel feststellt, die bei der statischen Codeanalyse nicht aufgedeckt werden, einschließlich unter anderem von Dienstleistungsverhinderungen aufgrund eines Versagens der Laufzeitabwicklung, von Speicherlecks und Zugriffen auf gemeinsam genutzte Speicher ohne Authentifikation. Diese Prüfungen müssen angewendet werden, wenn entsprechende Werkzeuge zur Verfügung stehen.

9.4.2 Begründung und zusätzliche Leitfäden

Leer.

9.5 SVV-4: Eindringprüfung

9.5.1 Anforderung

Es muss ein Prozess zur Kennzeichnung und Beschreibung sicherheitsbezogener Probleme mittels Prüfungen angewendet werden, die auf das Aufspüren und Ausnutzen von IT-Sicherheitslücken im Produkt ausgerichtet sind.

9.5.2 Begründung und zusätzliche Leitfäden

Die Schwerpunkte von Eindringprüfungen sind speziell die Gefährdung der Vertraulichkeit, der Integrität oder der Verfügbarkeit des Produkts. Dazu kann die Überwindung mehrerer Aspekte der gestaffelten Sicherheits-

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10

EN IEC 62443-4-1:2018

strategie gehören. Ein Beispiel dafür ist die Umgehung der Authentifikation für einen Zugriff auf das Produkt durch eine Erweiterung der Berechtigung, um einen administrativen Zugriff zu erhalten, und anschließend die Gefährdung der Vertraulichkeit durch das Brechen der Verschlüsselung. Wie dieses Beispiel zeigt, beinhaltet die Eindringprüfung ein Herangehen an die Prüfung in der Weise eines Angreifers und häufig die Ausnutzung verketteter Sicherheitslücken in einem Produkt.

Dieser Prozess ist erforderlich, um sicherzustellen, dass Anstrengungen unternommen worden sind, um sicherheitsbezogene Probleme im Produkt oder in der Produktdokumentation aufzudecken, die eine Ausnutzung des Produkts ermöglichen können.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller versucht, die IT-Sicherheit des Produkts durch eine Eindringprüfung zu verletzen. Eine Eindringprüfung besteht in der Bestätigung, dass Sicherheitslücken in einer beliebigen Fähigkeit des Produkts oder in der gestaffelten Sicherheitsstrategie ausgenutzt und zur Gefährdung der IT-Sicherheit des Produkts genutzt werden können. Dies erfordert eine genaue Kenntnis des zu prüfenden Produkttyps zusammen mit Werkzeugen und Verfahren zur Prüfung der IT-Sicherheit. Eindringprüfungen können die Anwendung von manuellen Verfahren, Prüfwerkzeugen oder einer Kombination dieser zwei einschließen.

9.6 SVV-5: Unabhängigkeit der Prüfer

9.6.1 Anforderung

Es muss ein Prozess angewendet werden, um sicherzustellen, dass Einzelpersonen, die Prüfungen durchführen, nach Tabelle 3 unabhängig von den Entwicklern sind, welche das Produkt entworfen und implementiert haben.

Tabelle 3 – Geforderter Grad der Unabhängigkeit der Prüfer von den Entwicklern

Art der Prüfung	Verweisungen	Grad der Unabhängigkeit
Prüfung der IT-Sicherheitsanforderungen	SVV-1 – Prüfung der IT-Sicherheitsanforderungen	Unabhängige Abteilung
Prüfung der Bedrohungsabschwächung	SVV-2 – Prüfung der Bedrohungsabschwächung	Unabhängige Abteilung
Prüfung von Missbrauchsfällen	SVV-3 – Prüfung von Sicherheitslücken	Unabhängige Person
Statische Codeanalyse	SI-1 – Überprüfung der gesicherten Implementierung	Keine
Analyse der Angriffsfläche	SVV-3 – Prüfung von Sicherheitslücken	Unabhängige Person
Scan auf bekannte Sicherheitslücken	SVV-3 – Prüfung von Sicherheitslücken	Unabhängige Person
Analyse der Softwarezusammensetzung	SVV-3 – Prüfung von Sicherheitslücken	Keine
Eindringprüfung	SVV-4 – Eindringprüfung	Unabhängige Abteilung oder Organisation

Es werden folgende Grade der Unabhängigkeit festgelegt:

- **Keiner** – Keine Unabhängigkeit erforderlich. Die Prüfung kann vom Entwickler durchgeführt werden.
- **Unabhängige Person** – Die Person, die die Prüfung durchführt, kann keiner der Produktentwickler sein.
- **Unabhängige Abteilung** – Die Person, die die Prüfung durchführt, kann keinen Bericht an denselben direkten Vorgesetzten weitergeben, an den auch Produktentwickler berichten. Alternativ könnte sie ein Mitglied einer Abteilung der Qualitätssicherung (QA) sein.
- **Unabhängige Organisation** – Die Person, die die Prüfung durchführt, kann nicht Teil derselben Organisation sein, zu der ein beliebiger Produktentwickler gehört. Eine Organisation kann eine getrennte juristische Instanz, ein Bereich eines Unternehmens oder eine Abteilung eines Unternehmens sein, die bzw. der an eine andere Führungskraft wie einen Geschäftsführer oder an eine ähnliche Ebene berichtet.

9.6.2 Begründung und zusätzliche Leitfäden

Ein unabhängiger Prüfer kann häufig mehr, andere und verschiedenartige Fehler entdecken, als ein Prüfer, der innerhalb eines Programmiererteams arbeitet oder ein Prüfer der beruflich programmiert. Ein solcher Prüfer bringt andere Annahmen in die Prüfungen und Bewertungen ein, die häufig eine Unterstützung bei der Aufdeckung versteckter Fehler und Probleme bieten. Darüber hinaus kann ein unabhängiger Prüfer, der dem Führungstab berichtet, seine Ergebnisse unvoreingenommen weitergeben und ohne Repressalien befürchten zu müssen, die sich durch die Hinweise auf Probleme in der Arbeit von Kollegen oder noch schlimmer der Führungskräfte ergeben können.

Weitere IT-Sicherheitsmängel können häufig aufgedeckt werden, wenn der „Black-Box“-Kenntnisstand eines Prüfers durch den „Black-Box“-Kenntnisstand eines Prüfers ergänzt wird, der als Berater des Prüfers tätig ist.

10 Ansatz 6 – Behandlung sicherheitsbezogener Probleme

10.1 Zweck

Die von diesem Ansatz festgelegten Prozesse dienen der Behandlung sicherheitsbezogener Probleme eines Produkts, das so konfiguriert wurde, dass seine Defense-in-Depth-Strategie (siehe [Abschnitt 7](#)) innerhalb des IT-Sicherheitsumfelds des Produkts (siehe [Abschnitt 6](#)) eingesetzt wird.

10.2 DM-1: Empfang von Meldungen über sicherheitsbezogene Probleme

10.2.1 Anforderung

Es muss ein Prozess für den Empfang und die abschließende Verfolgung sicherheitsbezogener Probleme im Produkt vorhanden sein, die von internen und externen Quellen gemeldet werden, zu denen mindestens die Folgenden gehören:

- a) Prüfer für die Verifikation und Validierung der IT-Sicherheit;
- b) Hersteller von Fremdkomponenten, die im Produkt eingesetzt werden;
- c) Produktentwickler und -prüfer; und
- d) Produktanwender einschließlich Integratoren, Betreiber und Instandhaltungspersonal.

ANMERKUNG Zu externen Prüfern für die Verifikation und Validierung der IT-Sicherheit gehören auch Spezialisten.

10.2.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass sicherheitsbezogene Probleme/Fehler, die von einer beliebigen Organisation innerhalb der Herstellerorganisation oder von externen Organisationen aufgedeckt werden (z. B. Kunden und Sicherheitsspezialisten), dem Hersteller gemeldet und bis zum Abschluss verfolgt werden können.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller Anweisungen für die Meldung sicherheitsbezogener Probleme an ihn festgelegt hat (siehe ISO/IEC 30111 [\[23\]](#)). Für Berichte externer Instanzen besitzt der Hersteller Prozesse für das Verhalten bei Vorfällen, wie sie in ISO/IEC 29147 [\[22\]](#) für den Empfang von Berichten über Sicherheitslücken von unterstützten Produkten und die Wechselwirkung mit der Stelle, die das Problem gemeldet hat, angegeben sind.

Richtlinien für die Meldung sicherheitsbezogener Probleme müssen für jede mögliche interne oder externe Quelle dieser Berichte einfach zugänglich sein. Mögliche Wege für die Weitergabe dieser Informationen sind Wahrnehmungsschulungen, Produktdokumentationen und Support-Webseiten. Diese Richtlinien beinhalten:

- a) Informationen, die die Validierung erleichtern;
- b) wie die Vertraulichkeit der gemeldeten Informationen und der Zugriff auf diese zu schützen sind;
- c) den Umfang der Kommunikation mit der Instanz, die das sicherheitsbezogene Problem gemeldet hat;

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10

EN IEC 62443-4-1:2018

- d) Zeitvorgaben für die Meldung intern aufgedeckter sicherheitsbezogener Probleme in freigegebenen Produkten; und
- e) eine Strategie für die Behandlung von Sicherheitslücken in Fremdkomponenten, die intern festgestellt wurden.

10.3 DM-2: Überprüfung sicherheitsbezogener Probleme

10.3.1 Anforderung

Es muss ein Prozess vorhanden sein, mit dem sichergestellt wird, dass gemeldete sicherheitsbezogene Probleme rechtzeitig untersucht werden, um das Folgende zu ermitteln:

- a) ihre Anwendbarkeit für das Produkt;
- b) Verifizierbarkeit; und
- c) Bedrohungen, die das Problem auslösen.

ANMERKUNG Die Aktualität wird durch die Gegebenheiten des Marktes bestimmt.

10.3.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass dem Hersteller gemeldete sicherheitsbezogene Probleme untersucht werden, um zu ermitteln, ob sie für das Produkt anwendbar sind, sie verifizierbar sind und der Grund für das Problem (z. B. die Bedrohung(en)) nachvollzogen werden kann.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller alle ihm gemeldeten IT-Sicherheitsprobleme bestätigt. Erkannte sicherheitsbezogene Probleme können unberechtigt oder für das Produkt unzutreffend sein, so dass ein Prozess vorhanden sein muss, um gemeldete Sicherheitslücken zu bestätigen und zu untersuchen (siehe ISO/IEC 30111).

Bei sicherheitsbezogenen Problemen in Komponenten, die vom Produktentwickler gepflegt werden, kann dieser Prozess solche Aktivitäten umfassen wie den Versuch der Nachbildung der gemeldeten Sicherheitslücke oder die Untersuchung des Einsatzes eines eingebetteten Fremd-Quellcodes innerhalb des Produkts. Bei sicherheitsbezogenen Problemen in Komponenten, die von Fremdanbietern gepflegt werden, kann dieser Prozess einfach im Vergleich der Version des Fremd-Binärcodes mit den Versionen sein, für die der Patch gilt.

10.4 DM-3: Bewertung sicherheitsbezogener Probleme

10.4.1 Anforderung

Es muss ein Prozess zur Analyse sicherheitsbezogener Probleme im Produkt angewendet werden, der das Folgende umfasst:

- a) die Bewertung ihrer Auswirkung in Bezug auf:
 - 1) das tatsächliche IT-Sicherheitsumfeld, in dem sie festgestellt wurden;
 - 2) das IT-Sicherheitsumfeld des Produkts (siehe [Abschnitt 6](#)); und
 - 3) die Defense-in-Depth-Strategie des Produkts (siehe [Abschnitt 7](#));
- b) den Schweregrad, wie durch ein Verwundbarkeitsbewertungssystem (z. B. CVSS) festgelegt;
- c) die Kennzeichnung aller anderen Produkte/Produktversionen, die das sicherheitsbezogene Problem (soweit vorhanden) betrifft;
- d) die Kennzeichnung der Grundursache des Problems; und
- e) die Kennzeichnung zugehöriger IT-Sicherheitsprobleme.

Für eine Analyse der Grundursache darf ein methodischer Ansatz nach IEC 62740 [\[25\]](#) angewendet werden.

10.4.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass der mögliche Einfluss sicherheitsbezogener Entwurfsprobleme untersucht wird und nachvollzogen werden kann, um Entscheidungen zu untermauern, die sich auf ihre Behandlung beziehen.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller die mögliche Auswirkung und den Schweregrad jedes sicherheitsbezogenen Problems bewertet, dass er ermittelt, ob die Probleme in anderen Produkten oder Versionen vorhanden sind (z. B. durch Anwendung der gleichen oder ähnlicher Komponenten) und dass er die Grundursache des Problems bestimmt. Die Durchführung einer solchen Bewertung bietet die Grundlage für die Bestimmung, wie das Problem zu behandeln ist (siehe 10.5), und welche Prozesse des Entwicklungslebenszyklus wie ein Neuentwurf und Aktualisierungen des Bedrohungsmodells in die Lösung einbezogen werden können.

ANMERKUNG Für diese Bewertung sicherheitsbezogener Probleme können Risikobewertungen durchgeführt werden.

Die Auswirkung gültiger sicherheitsbezogener Probleme auf die IT-Sicherheit und ihre Verteilung innerhalb des Produkts können vielfältig sein, so dass ein Prozess vorhanden sein muss, um jedes Problem zu beschreiben, damit eine geeignete Lösung bestimmt werden kann.

Es wird ein Prozess empfohlen, der Bedingungen kennzeichnet, unter denen der Prozess der Behandlung von Mängeln der IT-Sicherheit beendet wird, wie ein bereits bekanntes und behandeltes Problem (Kopie), ein nicht sicherheitsbezogenes Problem und ein sicherheitsbezogenes Problem eines Fremdanbieters (siehe ISO/IEC 30111). Bei der Folgenabschätzung sollten außerdem zusätzliche Faktoren wie der Umfang der betroffenen Produkthanwender, die Möglichkeit von Kollateralschäden, die Verfügbarkeit von Exploits und (bei Automatisierungssystemen) die mögliche Auswirkung auf Hauptfunktionen (IEC 62443-3-3) berücksichtigt werden.

Die Folgenabschätzung kann so einfach sein wie eine qualitative Bewertung (z. B. gering, mittel und hoch), eine eher quantitative Methode auf der Basis der Wahrscheinlichkeit und der Folgen oder ein genormtes Verfahren wie das CVSS. Ein sicherheitsbezogenes Problem im Zusammenhang mit einem weitverbreiteten Entwurfsmuster oder einer häufig genutzten Implementierungsmethode kann symptomatisch für ein größeres Problem sein. In einer solchen Situation sollte die mit der Sicherheitslücke verbundene Folgenabschätzung die kombinierte Auswirkung aller Fälle und nicht jeden Fall einzeln behandeln.

10.5 DM-4: Behandlung sicherheitsbezogener Probleme

10.5.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem sicherheitsbezogene Probleme behandelt werden und bestimmt wird, ob sie aufgrund der Ergebnisse der Folgenabschätzung (siehe 10.4) zu melden sind. Der Hersteller muss ein annehmbares Restrisikoniveau aufstellen, das bei der entsprechenden Behandlung des jeweiligen Problems angewendet werden muss. Möglichkeiten dafür sind:

- a) Beheben des Problems durch:
 - 1) eine Defense-in-Depth-Strategie oder eine Entwurfsänderung;
 - 2) die Ergänzung einer oder mehrerer Anforderungen und/oder Fähigkeiten im Hinblick auf die IT-Sicherheit;
 - 3) die Anwendung von Kompensationsmechanismen; und/oder
 - 4) das Deaktivieren oder Entfernen von Merkmalen;
- b) Aufstellen eines Mängelbeseitigungsplans zur Behebung des Problems;
- c) Aufschieben des Problems in eine zukünftige Lösung (Neuanwendung dieser Anforderung zu einem bestimmten Zeitpunkt in der Zukunft) und Festlegen des Grundes (der Gründe) und des (der) damit verbundenen Risikos (Risiken);
- d) Nichtbeheben des Problems, wenn das Restrisiko unter dem aufgestellten annehmbaren Restrisikoniveau liegt.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

In allen Fällen muss auch das Folgende durchgeführt werden:

- a) Information anderer Prozesse über das Problem oder zugehöriger Probleme einschließlich von Prozessen für andere Produkte/Produktüberarbeitungen; und
- b) Information von Fremdanbietern, wenn Probleme im integrierten Quellcode von Fremdanbietern aufgedeckt wurden.

Wenn sicherheitsbezogene Probleme gelöst werden, sollten Empfehlungen dafür gegeben werden, um zukünftig ähnliche Fehler zu vermeiden.

Dieser Prozess muss eine periodische Überprüfung von offenen sicherheitsbezogenen Problemen umfassen, um sicherzustellen, dass Probleme angemessen behandelt werden. Diese periodische Überprüfung muss mindestens während jedes Freigabe- oder Iterationszyklus erfolgen.

ANMERKUNG Wenn die Lösungsentscheidung die Behebung des sicherheitsbezogenen Problems bei der Implementierung des Produkts ist, kann die Zeitvorgabe für die Freigabe der Behebung zu einem Patch führen (siehe [Abschnitt 12](#)) oder die Behebung kann bis zur nächsten Freigabe aufgeschoben werden.

10.5.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass bestimmt wird, wie das jeweilige sicherheitsbezogene Problem zu behandeln ist, und dass kein sicherheitsbezogenes Problem unbeabsichtigt übersehen oder vernachlässigt wird.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller das mögliche Restrisiko des jeweiligen sicherheitsbezogenen Problems überprüft und eine vertretbare Entscheidung für dessen Behandlung trifft. Das Restrisiko kann nach vielen verschiedenen Methoden bestimmt werden. Ein Beispiel ist die Einleitung eines CVSS und anschließend die Ergänzung weiterer IT-Sicherheitsmaßnahmen und Maßnahmen, die bei der CVSS-Auswertung nicht berücksichtigt wurden, je nachdem, ob das Problem für das IT-Sicherheitsumfeld des Produkts zutrifft.

Der Prozess der Entscheidung über eine Lösung eines sicherheitsbezogenen Problems und deren Umsetzung muss wegen seiner möglichen Auswirkungen die folgenden Überlegungen (siehe ISO/IEC 30111) berücksichtigen:

- a) eine empfohlene Lösung kann eine Bedingung des gesicherten Entwurfs verletzen, auf der andere Aspekte des Produkts beruhen;
- b) eine empfohlene Lösung kann aufgrund einer Diskrepanz zwischen dem gemeldeten Sicherheitsumfeld einer Instanz und dem IT-Sicherheitsumfeld des Produkts unnötig sein;
- c) eine empfohlene Lösung kann die Auswirkung des sicherheitsbezogenen Problems nur teilweise abschwächen, kann wegen ihrer Komplexität eine unannehmbar lange Umsetzungsdauer erfordern oder ist möglicherweise so unbrauchbar, dass sie wahrscheinlich deaktiviert wird;
- d) eine empfohlene Lösung kann Nebenwirkungen einführen, die untragbar sind.

Die auf die Auswirkung des sicherheitsbezogenen Problems gestützte Zeitvorgabe für die Bestimmung und Umsetzung einer Lösung richtet sich in der Regel nach den Marktgegebenheiten und kann die Einrichtung eindeutiger Schnittstellen mit den betreffenden Organisationsprozessen fördern (z. B. Rechtsbeziehungen, Kundendienst und Öffentlichkeitsarbeit), um unnötige Verzögerungen zu verhindern.

10.6 DM-5: Offenlegung sicherheitsbezogener Probleme

10.6.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem Produktanwender über meldepflichtige, sicherheitsbezogene Probleme (siehe [10.5](#)) in unterstützten Produkten rechtzeitig informiert werden, mit einem Inhalt, der unter anderem folgende Informationen enthält:

- a) eine Problembeschreibung, eine Verwundbarkeitsbewertung mit CVSS oder einem ähnlichen System für die Einordnung von Sicherheitslücken und die betroffene(n) Produktversion(en); und

b) eine Beschreibung der Lösung.

ANMERKUNG 1 Die Beschreibung der Lösung kann Verweisungen auf die Installation von Patches (siehe Abschnitt 12) umfassen.

ANMERKUNG 2 Die Rechtzeitigkeit wird durch die Marktgegebenheiten bestimmt.

Die Strategie für die Behandlung von Sicherheitslücken in Fremdkomponenten, die vom Produktentwickler festgestellt werden, sollte die Möglichkeit einer vorhergehenden Offenlegung durch den Hersteller der Fremdkomponente berücksichtigen.

10.6.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Kunden über gelöste sicherheitsbezogene Probleme informiert werden, die als meldepflichtig bezeichnet wurden. Meldepflichtige Lösungen sind in der Regel solche, die sich auf freigegebene Produkte beziehen, bei denen der Schweregrad des Problems als so hoch angesehen wird, dass sie vom Hersteller gemeldet werden. Produktanwender benötigen diese Information, um fundierte IT-Sicherheitsbewertungen über ihre Operationen anzustellen, und Dienstleister nutzen diese Information zur Behandlung von Sicherheitslücken als Teil ihrer Fähigkeit zur Behandlung von Ereignissen (siehe IEC 62443-2-4).

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller Vorgehensweisen zur Bestimmung, welche IT-Sicherheitsprobleme meldepflichtig sind, und zur Meldung von Lösungen für meldepflichtige Probleme an die Betreiber des Produkts besitzt. Der Offenlegungsprozess umfasst in der Regel Vorkehrungen für informatorische Warnungen zusätzlich zu Mitteilungen über Sicherheitslücken. Mit informatorischen Warnungen können Produktanwendern z. B. Kompensationsmechanismen angesichts laufender Aktivitäten der IT-Sicherheit mitgeteilt werden oder Produktanwender können darüber informiert werden, dass das Produkt nicht anfällig für eine öffentlichkeitswirksame Sicherheitslücke ist. Informationen über den Inhalt von Benachrichtigungen können IEC 29147 [22] entnommen werden.

10.7 DM-6: Periodische Überprüfung der Behandlungsverfahren für Mängel der IT-Sicherheit

10.7.1 Anforderung

Es muss ein Prozess zur periodischen Durchführung von Überprüfungen des Prozesses der Behandlung von sicherheitsbezogenen Problemen angewendet werden. Periodische Überprüfungen des Prozesses müssen mindestens sicherheitsbezogene Probleme untersuchen, die von diesem Prozess seit der letzten periodischen Überprüfung behandelt wurden, um zu ermitteln, ob der Prozess der Behandlung vollständig und wirksam war und zur Lösung jedes sicherheitsbezogenen Problems führte. Periodische Überprüfungen des Prozesses der Behandlung von sicherheitsbezogenen Problemen müssen mindestens jährlich durchgeführt werden.

10.7.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist für eine ständige Verbesserung der Vorgehensweise bei der Problembehandlung erforderlich.

11 Ansatz 7 – Verwaltung von IT-Sicherheits-Updates

11.1 Zweck

Die durch diesen Ansatz festgelegten Prozesse werden angewendet, um sicherzustellen, dass Regressionsprüfungen von IT-Sicherheits-Updates im Zusammenhang mit dem Produkt durchgeführt und die IT-Sicherheits-Updates dem Produktanwender rechtzeitig zur Verfügung gestellt werden.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

11.2 SUM-1: Eignung von IT-Sicherheits-Updates

11.2.1 Anforderung

Es muss ein Prozess angewendet werden, um zu verifizieren, dass:

- 1) vom Produktentwickler erstellte IT-Sicherheits-Updates die vorgesehenen IT-Sicherheitslücken behandeln;
- 2) IT-Sicherheits-Updates keine Regressionen einführen, einschließlich unter anderem von Patches, die erstellt werden von:
 - a) dem Produktentwickler;
 - b) Herstellern von Komponenten, die im Produkt verwendet werden; und
 - c) Herstellern von Komponenten oder Plattformen, von denen das Produkt abhängt.

Der Prozess sollte eine Bestätigung umfassen, dass ein Update nicht anderen betrieblichen Sachzwängen und sicherheitsbezogenen oder rechtlichen Beschränkungen entgegensteht.

11.2.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass für das Produkt zutreffende Patches bewertet werden, um sicherzustellen, dass sie den Betrieb des Produkts nicht nachteilig beeinflussen.

Die Umsetzung dieses Prozesses bedeutet, dass die Eignung von Patches (in der Regel mit Prüfungen) nachgewiesen und bestätigt wird, dass die für das Produkt anwendbaren Patches den Betrieb des Produkts oder die Defense-in-Depth-Strategie weder direkt noch indirekt (z. B. über Nebenwirkungen) gefährden (siehe [Abschnitt 7](#)). Vom Dienstleister darf die Dokumentation über diesen Prozess genutzt werden, um die Anforderungen an das Patch-Management nach IEC 62443-2-4 zu behandeln.

11.3 SUM-2: Dokumentation von IT-Sicherheits-Updates

11.3.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem sichergestellt wird, dass den Produktanwendern eine Dokumentation über IT-Sicherheits-Updates für das Produkt zur Verfügung gestellt wird, die unter anderem das Folgende enthält:

- a) die Versionsnummer(n) des Produkts, für die der IT-Sicherheitspatch gilt;
- b) Anweisungen, wie zugelassene Patches manuell oder mit einem automatisierten Prozess anzuwenden sind;
- c) eine Beschreibung aller Auswirkungen, die die Anwendung des Patches auf das Produkt nach sich zieht, einschließlich eines Reboots (de: Neustart);
- d) Anweisungen, wie nachzuweisen ist, dass ein zugelassener Patch angewendet worden ist; und
- e) Risiken, die entstehen, wenn der Patch und Vermittlungen (en: mediations), die für vom Betreiber nicht zugelassene oder nicht eingesetzte Patches verwendet werden können, nicht angewendet werden.

11.3.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass IT-Sicherheitspatches dokumentiert werden, damit zugelassene Patches installiert werden können und nicht zugelassene Patches korrigiert werden.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Dokumentation mit einer Beschreibung anwendbarer IT-Sicherheitspatches vorlegt oder anders bekannt macht, wie die zugelassenen Patches zu installieren sind, wie der Patchstatus von Komponenten zu bestimmen ist (ob ein Patch angewendet worden ist) und wie nicht zugelassene Patches bereinigt werden. Weitere Informationen zum Patch-Management können IEC 62443-2-4 entnommen werden.

11.4 SUM-3: Dokumentation der IT-Sicherheits-Updates für abhängige Komponenten oder Betriebssysteme

11.4.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem sichergestellt wird, dass den Produktanwendern eine Dokumentation über IT-Sicherheits-Updates für abhängige Komponenten oder Betriebssysteme zur Verfügung gestellt wird, die unter anderem das Folgende enthalten:

- a) eine Angabe, ob das Produkt mit dem IT-Sicherheits-Update für die abhängige Komponente oder das Betriebssystem kompatibel ist; und
- b) bei IT-Sicherheits-Updates, die vom Produktanbieter nicht zugelassen sind, die Abschwächungsmaßnahmen, die angewendet werden, wenn das Update nicht eingesetzt wird.

11.4.2 Begründung und zusätzliche Leitfäden

Betreiber zögern bei der Installation von Software in einem IACS, die Störungen des Betriebs mit sich bringen können. Infolgedessen müssen Anbieter dem Anwender Informationen darüber liefern, ob ein bestimmtes IT-Sicherheits-Update für das Betriebssystem mit dem Produkt kompatibel ist.

11.5 SUM-4: Auslieferung von IT-Sicherheits-Updates

11.5.1 Anforderung

Es muss ein Prozess angewendet werden, mit dem sichergestellt wird, dass den Produktanwendern IT-Sicherheits-Updates für alle unterstützten Produkte und Produktversionen in einer Weise zur Verfügung gestellt werden, die eine Nachweisprüfung ermöglichen, dass ein IT-Sicherheitspatch echt ist.

11.5.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass dem Produktanwender für das Produkt geltende IT-Sicherheitspatches rechtzeitig zur Verfügung gestellt werden und die Möglichkeit verringert wird, dass die IT-Sicherheitspatches betrügerisch sind (siehe [Abschnitt 11](#)).

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller einen Mechanismus oder ein Verfahren bereitstellt, mit dem Produktanwender die Echtheit von Patches nachweisen können. Die gleichzeitige Freigabe von Patches für alle unterstützten Versionen kann das Zeitfenster zwischen der Wahrnehmung der Sicherheitslücke und der Verfügbarkeit von Patches verringern.

11.6 SUM-5: Rechtzeitige Auslieferung von IT-Sicherheitspatches

11.6.1 Anforderung

Es muss ein Prozess angewendet werden, um Leitlinien festzulegen, die den Zeitrahmen für die Lieferung und Qualifizierung (siehe [11.2](#)) von IT-Sicherheits-Updates an/für Produktanwender festlegt, und um sicherzustellen, dass diese Leitlinien befolgt werden. Diese Leitlinien müssen mindestens die folgenden Faktoren berücksichtigen:

- a) die mögliche Auswirkung der Sicherheitslücke;
- b) die öffentliche Kenntnis der Sicherheitslücke;
- c) ob veröffentlichte Exploits für die Sicherheitslücke vorhanden sind;
- d) den Umfang der eingesetzten Produkte, die betroffen sind; und
- e) die Verfügbarkeit einer wirksamen Abschwächungsmaßnahme anstelle des Patches.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

11.6.2 Begründung und zusätzliche Leitfäden

IT-Sicherheits-Updates haben in der Regel Zielfreigabezeiten, die auf den in dieser Anforderung aufgeführten Faktoren beruhen. Einige Unternehmen teilen Patches z. B. so ein, dass sie innerhalb von 30, 60 oder 90 Tagen oder länger nach der Feststellung behandelt werden müssen.

12 Ansatz 8 – IT-Sicherheitsrichtlinien

12.1 Zweck

Die von diesem Ansatz festgelegten Prozesse dienen der Bereitstellung einer Dokumentation, die beschreibt, wie die Defense-in-Depth-Strategie des Produkts in Übereinstimmung mit seinem IT-Sicherheitsumfeld zu integrieren, zu konfigurieren und zu pflegen ist (siehe [Abschnitt 6](#)). IEC 62443-2-4 legt ergänzende Härtingsanforderungen für die Anwendung dieser Dokumentation durch IACS-Dienstleister fest.

Die Anwendung und Pflege der gestaffelten Sicherheitsstrategie für eine spezifische Installation beinhaltet in der Regel das Folgende:

- Leitlinien und Vorgehensweisen im Zusammenhang mit dem IT-Sicherheitsumfeld des Produkts nach den Festlegungen in [Abschnitt 6](#);
- architektonische Betrachtungen wie die Anordnung der Firewall und die Nutzung von Kompensationsmechanismen einschließlich von IT-Sicherheitsmaßnahmen nach den Festlegungen in [Abschnitt 7](#);
- das Konfigurieren von IT-Sicherheitseinstellungen/-optionen wie das Konfigurieren von Firewall-Richtlinien, die Befugnisübertragung, die Zertifikatsverwaltung und die Verwaltung von Nutzerkonten (z. B. Einstellung ihrer Rechte/Berechtigungen); und
- die Nutzung von Werkzeugen zur Unterstützung der Härtung.

ANMERKUNG In dieser Liste ist die Anwendung von Patches nicht enthalten, die aber in [Abschnitt 11](#) behandelt wird.

Der Rest des Abschnitts 12 definiert Anforderungen an Entwicklungsprozesse, die für die Erstellung und Pflege dieser Dokumentation angewendet werden. Die Unterstützung dieser Anforderungen bedeutet, dass der Hersteller nachvollziehbare Prozesse für die Erstellung, Pflege und Lieferung einer Dokumentation besitzt, die beschreiben, wie das Produkt zu härten ist.

12.2 SG-1: Defense-in-Depth-Strategie für das Produkt

12.2.1 Anforderung

Es muss ein Prozess für die Dokumentation der gestaffelten Sicherheitsstrategie für das Produkt zur Unterstützung von Installation, Betrieb und Instandhaltung vorhanden sein, der das Folgende umfasst:

- Fähigkeiten im Hinblick auf die IT-Sicherheit, die vom Produkt umgesetzt werden, und deren Rolle innerhalb der gestaffelten Sicherheitsstrategie;
- Bedrohungen, die durch die Defense-in-Depth-Strategie behandelt werden; und
- Abschwächungsstrategien des Betreibers für bekannte Sicherheitsrisiken im Zusammenhang mit dem Produkt einschließlich von Risiken im Zusammenhang mit der Bestandssoftware (Legacy Code).

12.2.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die Dokumentation der gestaffelten Sicherheitsstrategie so erstellt wird, dass die Härtung des Produkts auf der Kundenseite unterstützt wird. Eine solche Dokumentation wird von IEC 62443-2-4 gefordert, die IT-Sicherheitsanforderungen für IACS-Installations- und Instandhaltungsdienstleister festlegt.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller verschiedene Aspekte der gestaffelten Sicherheitsstrategie dokumentiert, die erforderlich sind, um das Produkt während der Installation zu härten und diese Härtung während seiner gesamten Lebensdauer zu erhalten. Zu den Aspekten der gestaffelten

Sicherheitsstrategie, die zu dokumentieren sind, gehören die Restbedrohungen, die zu erwarten sind und das Produkt angreifen können, die Fähigkeiten im Hinblick auf die IT-Sicherheit des Produkts, um es gegen diese Bedrohungen zu schützen, und jegliche kompensierenden IT-Sicherheitsmaßnahmen/Abschwächungsmaßnahmen, die mit dem Produkt umgesetzt werden können, um dieses weiterhin zu schützen.

12.3 SG-2: Maßnahmen des Defense-in-Depth-Konzepts, die von der Umgebung zu erwarten sind

12.3.1 Anforderung

Es muss ein Prozess vorhanden sein, mit dem die Maßnahmen des Defense-in-Depth-Konzepts dokumentiert werden, die von der äußeren Umgebung bereitgestellt werden, in der das Produkt anzuwenden ist (siehe [Abschnitt 6](#)).

ANMERKUNG Diese Maßnahmen können auch [10.5](#) entnommen werden.

12.3.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die Dokumentation der gestaffelten Sicherheitsstrategie so erstellt wird, dass die Härtung des Produkts auf der Kundenseite unterstützt wird. Eine solche Dokumentation wird von IEC 62443-2-4 gefordert, die IT-Sicherheitsanforderungen für IACS-Installations- und Instandhaltungsdienstleister festlegt.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller verschiedene Aspekte der gestaffelten Sicherheitsstrategie dokumentiert, die erforderlich sind, um das Produkt während der Installation zu härten und diese Härtung während seiner gesamten Lebensdauer zu erhalten.

12.4 SG-3: Richtlinien für die Härtung der IT-Sicherheit

12.4.1 Anforderung

Es muss ein Prozess angewendet werden, um eine Dokumentation für Produkthanwender zu erstellen, die Richtlinien für die Härtung des Produkts bei dessen Installation und Pflege enthält. Die Richtlinien schließen unter anderem Anweisungen, Begründungen und Empfehlungen für das Folgende ein:

- a) die Integration des Produkts mit seinem IT-Sicherheitsumfeld einschließlich von Fremdkomponenten (siehe [Abschnitt 6](#));
- b) die Integration der Anwendungsprogrammierschnittstellen/-protokolle des Produkts mit Nutzeranwendungen;
- c) die Anwendung und Pflege der Defense-in-Depth-Strategie des Produkts (siehe [Abschnitt 7](#));
- d) die Konfiguration und Nutzung der Optionen/Fähigkeiten im Hinblick auf die IT-Sicherheit zur Unterstützung örtlicher IT-Sicherheitsrichtlinien und für jede Option/Fähigkeit im Hinblick auf die IT-Sicherheit:
 - 1) ihren Beitrag zur Defense-in-Depth-Strategie des Produkts (siehe [Abschnitt 7](#));
 - 2) Beschreibungen von konfigurierbaren und voreingestellten Werten, die einschließen, wie die IT-Sicherheit jeweils beeinflusst wird, zusammen mit jeglichen möglichen Auswirkungen auf die Arbeitspraxis; und
 - 3) die Einstellung/Änderung/Löschung ihrer Werte;
- e) Anweisungen und Empfehlungen für die Nutzung aller sicherheitsbezogenen Werkzeuge und Sicherheitsfunktionen, die die Verwaltung, Überwachung, Vorfallsbehandlung und Bewertung der IT-Sicherheit des Produkts unterstützen;
- f) Anweisungen und Empfehlungen für periodische Aktivitäten zur Erhaltung der Sicherheit;
- g) Anweisungen für die Meldung von IT-Sicherheitsvorfällen für das Produkt an den Hersteller; und
- h) Beschreibung bewährter IT-Sicherheitsverfahren für die Instandhaltung und Verwaltung des Produkts.

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 EN IEC 62443-4-1:2018

12.4.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Anweisungen dokumentiert werden, die beschreiben, wie das Produkt zu härten ist und diese Härtung erhalten wird. Eine solche Dokumentation wird von IEC 62443-2-4 gefordert, die IT-Sicherheitsanforderungen für IACS-Installations- und Instandhaltungsdienstleister festlegt.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Benutzerdokumentation erstellt, die Hinweise für die Härtung des Produkts während der Installation und für die Erhaltung der Härtung während der Lebensdauer des Produkts gibt. Diese Anforderung berücksichtigt, dass die IT-Sicherheitsleitlinien und die Anforderungen für die Kundenstandorte häufig verschieden sind und infolgedessen Anweisungen für eine gesicherte Integration des Produkts am Standort des Kunden, dessen angemessene Konfiguration und die Erhaltung seiner IT-Sicherheit notwendig sind.

12.5 SG-4: Richtlinien für eine gesicherte Entsorgung

12.5.1 Anforderung

Es muss ein Prozess angewendet werden, um eine Benutzerdokumentation zu erstellen, die Richtlinien für die Außerbetriebnahme des Produkts enthält. Diese Richtlinien müssen unter anderem Anweisungen und Empfehlungen für das Folgende umfassen:

- a) das Entfernen des Produkts aus seiner vorgesehenen Umgebung (siehe [Abschnitt 6](#));
- b) die Aufnahme von Empfehlungen für die Entfernung von Referenz- und Konfigurationsdaten, die in der Umgebung gespeichert sind;
- c) das sichere Entfernen der im Produkt gespeicherten Daten; und
- d) die gesicherte Entsorgung des Produkts, um eine mögliche Offenlegung der im Produkt enthaltenen Daten, die nicht gemäß der vorgenannten Beschreibung in c) entfernt werden konnten, zu verhindern.

12.5.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Anweisungen dokumentiert werden, die beschreiben, wie das Produkt sicher zurückgezogen (außer Betrieb genommen) werden kann. Eine solche Dokumentation wird von IEC 62443-2-4 gefordert, die IT-Sicherheitsanforderungen für IACS-Installations- und Instandhaltungsdienstleister festlegt.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Benutzerdokumentation erstellt, die Hinweise für eine Bereinigung des Produkts von schützenswerten, vertraulichen und/oder hersteller-spezifischen Daten und Software gibt.

12.6 SG-5: Richtlinien für einen gesicherten Betrieb

12.6.1 Anforderung

Es muss ein Prozess angewendet werden, um eine Benutzerdokumentation zu erstellen, die das Folgende beschreibt:

- a) Verantwortlichkeiten und Aktionen, die Anwender und Administratoren für einen gesicherten Betrieb des Produkts durchführen müssen; und
- b) Annahmen hinsichtlich des Verhaltens des Anwenders/Administrators und dessen Beziehung zum gesicherten Betrieb des Produkts.

12.6.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Anweisungen in die IT-Sicherheitsrichtlinien aufgenommen werden, welche die gesicherte Anwendung des Produkts während seines Betriebs und seiner Administration beschreiben.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Benutzer-/Administratordokumentation erstellt, die Anweisungen für eine gesicherte Anwendung des Produkts gibt. Im Allgemeinen besteht diese Dokumentation aus einer Menge bewährter Verfahren für die gesicherte Anwendung des Produkts. Zum Beispiel könnte dies Richtlinien zur Zertifikatsverwaltung, Passwortverwaltung und anderer Authentifikationsmechanismen einschließen.

12.7 SG-6: Richtlinien für die Nutzerkontoverwaltung

12.7.1 Anforderung

Es muss ein Prozess angewendet werden, der die Anforderungen an Nutzerkonten und Empfehlungen im Zusammenhang mit der Anwendung des Produkts festlegt, die unter anderem das Folgende enthalten:

- a) Berechtigungen von Nutzerkonten (Zugriffskontrolle) und Rechte (Nutzerrechte), die für die Nutzung des Produkts erforderlich sind, einschließlich unter anderem von Betriebssystemkonten, Konten von Automatisierungssystemen und Datenbankkonten; und
- b) voreingestellte Konten, die vom Produkt genutzt werden (z. B. Dienstkonten), und Anweisungen für die Änderung voreingestellter Kontennamen und Passwörter.

12.7.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass Anforderungen an Nutzerkonten, die zur Nutzung des Produkts erforderlich sind, festgelegt und dokumentiert werden.

Die Umsetzung dieses Prozesses bedeutet, dass der Hersteller eine Dokumentation erstellt, die Konten und deren Einstellungen definiert, einschließlich von voreingestellten Konten, die für die Nutzung des Produkts erforderlich sind.

12.8 SG-7: Überprüfung der Dokumentation

12.8.1 Anforderung

Es muss ein Prozess angewendet werden, der Fehler und Auslassungen in allen Benutzerhandbüchern einschließlich der IT-Sicherheitsrichtlinien kennzeichnet, beschreibt und bis zum Abschluss verfolgt, und der das Folgende beinhaltet:

- a) den Umfang aller Fähigkeiten im Hinblick auf die IT-Sicherheit des Produkts;
- b) die Integration des Produkts in seiner vorgesehen Umgebung (siehe [Abschnitt 6](#)); und
- c) eine Versicherung, dass alle dokumentierten Verfahren sicher sind.

12.8.2 Begründung und zusätzliche Leitfäden

Dieser Prozess ist erforderlich, um sicherzustellen, dass die sicherheitsbezogene Dokumentation für das Produkt genau und vollständig ist und dass in anderen Benutzerdokumentationen keine nicht gesicherten Verfahren dokumentiert sind.

Die Umsetzung dieses Prozesses bedeutet, dass die sicherheitsbezogene Dokumentation des Produkts überprüft wird, um festzustellen, ob Fähigkeiten im Hinblick auf die IT-Sicherheit nicht richtig oder unzureichend behandelt wurden und ob die Dokumentation ausreichend beschreibt, wie die Defense-in-Depth-Strategie des Produkts in das IT-Sicherheitsumfeld des Produkts zu integrieren ist, und falls Diskrepanzen ermittelt wurden, ob ein Prozess zur Behandlung dieser Diskrepanzen besteht.

Anhang A (informativ)

Mögliche Maßgrößen

Abschnitt 5.15 erfordert von der Entwicklungsorganisation die Ausführung von Schritten zur ständigen Verbesserung ihres Prozesses. Die Verwendung von Maßgrößen, welche die Wirksamkeit des Entwicklungsprozesses aufzeigen, ist hilfreich bei der Ermittlung, ob messbare Verbesserungen erreicht wurden. Die spezifischen Maßgrößen, die zu erfassen sind (sofern vorhanden), liegen im Ermessen des Produktentwicklers und variieren möglicherweise erheblich, aber dieser Anhang A enthält einige Beispiele.

Als ein Beispiel kann der Ausgangsstand der IT-Sicherheitslage (SPS) wie folgt berechnet werden:

ANMERKUNG 1 Die tatsächlich vom Verkäufer angewendete Methode darf abweichen. Bei Nutzung einer Skala von 0 bis 100, wobei 100 den schlechtesten Wert angibt, werden mehrere Faktoren gemittelt, um die Punktzahl zu bestimmen.

a) Funktionale Sicherheit – gestützt auf in IEC 62443-4-2 festgelegte IT-Sicherheitsfunktionen

BEISPIEL 1 *NSF – NRM* normalisiert auf 100

Dabei ist

NSF die Anzahl von in IEC 62443-4-2 festgelegten IT-Sicherheitsfunktionen;

NRM die Anzahl solcher Anforderungen, die erfüllt werden.

b) IT-Sicherheit der Implementierung –

1) gestützt auf die Ergebnisse der SCA

BEISPIEL 2 $\left(1 - \left(\frac{NSCA}{NSR}\right)\right) \times 100$

Dabei ist

NSCA die SCA der aktivierten IT-Sicherheitsvorschriften der SCA, die 0 Warnungen zurückgeben;

NSR die Gesamtanzahl der IT-Sicherheitsvorschriften.

ANMERKUNG 2 Dieser Vorgang kann über mehrere Module gemittelt werden.

2) gestützt auf die Ergebnisse von banned.h

BEISPIEL 3 $\left(1 - \left(\frac{P}{TP}\right)\right) \times 100$

Dabei ist

P die Anzahl der Projekte, die mit banned.h verknüpft sind;

TP die Anzahl der Projekte, die verknüpft sein müssen.

c) IT-Sicherheit des Aufbaus – gestützt auf die Compiler-Optionen und Flags

BEISPIEL 4 $\left(1 - \left(\frac{B}{C}\right)\right) \times 100$

Dabei ist

B die Anzahl von Meldungen sauberer BinScope-Komponenten;

C die Anzahl von Komponenten.

- d) **IT-Sicherheit des Einsatzes** – gestützt auf die Ergebnisse einer Analyse der Angriffsfläche des Produkts

BEISPIEL 5 $\left(1 - \left(\frac{A}{N}\right)\right) \times 100$

Dabei ist

A die Anzahl der abgeschwächten Angriffsvektoren;

N die Gesamtanzahl der Angriffsvektoren.

- e) **Gegenwärtiger Rückstand** – gestützt auf die Anzahl kritischer oder erheblicher IT-Sicherheitsmängel im Produkt

BEISPIEL 6 $\text{MIN} ((50 \cdot CSI) + (10 \cdot (ISI)), 100)$

Dabei ist

CSI die Anzahl kritischer IT-Sicherheitsmängel;

ISI die Anzahl erheblicher IT-Sicherheitsmängel.

- f) **Schulung** – gestützt auf Bewertungspunkte der Techniker

BEISPIEL 7 $\left(1 - \left(\frac{CA}{SE}\right)\right) \times 100$

Dabei ist

CA die Anzahl abgeschlossener Bewertungen;

SE die Gesamtanzahl von Softwaretechnikern.

- g) **SDL-Verletzungen** – gestützt auf Abweichungen von den gesicherten Codierungsrichtlinien des SDL

BEISPIEL 8 $\left(1 - \left(\frac{CI}{CT}\right)\right) \times 100$

Dabei ist

CI die Anzahl der übereinstimmenden Elemente der Compliance-Checkliste des Codes;

CT die Gesamtanzahl der gesicherten Elemente in der Compliance-Checkliste des Codes.

ANMERKUNG 3 Die Anzahl der Elemente variiert je nach der Art des Codes wie Web, C++, Veraltet usw.

Anhang B
(informativ)**Tabelle der Anforderungen**

Tabelle B.1 fasst die Anforderungen zusammen und gibt einen Überblick über das vorliegende Dokument.

Tabelle B.1 – Zusammenfassung aller Anforderungen (1 von 2)

Nummer und Name der Anforderung
SM-1: Development process
SM-2: Identification of responsibilities
SM-3: Identification of applicability
SM-4: Security expertise
SM-5: Process scoping
SM-6: SM-6: File integrity
SM-7: Development environment security
SM-8: Controls for private keys
SM-9: Security requirements for externally provided components
SM-10: Custom developed components from third-party
SM-11: Assessing and addressing security-related issues
SM-12: Process verification
SM-13: Continuous improvement
SR-1: Product security context
SR-2: Threat model
SR-3: Product security requirements
SR-4: Product security requirements content
SR-5: Security requirements review
SD-1: Secure design principles
SD-2: Defense in depth design
SD-3: Security design review
SD-4: Secure design best practices
SI-1: Security implementation review
SI-2: Secure coding standards
SVV-1: Security requirements testing
SVV-2: Threat mitigation testing
SVV-3: Vulnerability testing
SVV-4: Penetration testing
SVV-5: Independence of testers

Tabelle B.1 (2 von 2)

Nummer und Name der Anforderung
DM-1: Receiving notifications of security-related issues
DM-2: Reviewing security-related issues
DM-3: Assessing security-related issues
DM-4: Addressing security-related issues
DM-5: Disclosing security-related issues
DM-6: Periodic review of security defect management practice
SUM-1: Security update qualification
SUM-2: Security update documentation
SUM-3: Dependent component or operating system security update documentation
SUM-4: Security update delivery
SUM-5: Timely delivery of security patches
SG-1: Product defense in depth
SG-2: Defense in depth measures expected in the environment
SG-3: Security hardening guidelines
SG-4: Secure disposal guidelines
SG-5: Secure operation guidelines
SG-6: Account management guidelines
SG-7: Documentation review

Literaturhinweise

Diese Literaturhinweise enthalten Verweisungen auf Quellen, die bei der Ausarbeitung dieser Norm verwendet wurden, sowie Verweisungen auf Quellen, die den Leser zu einem besseren Verständnis der IT-Sicherheit als Ganzes und des Entwicklungsprozesses eines IT-Sicherheit-Managementsystems verhelfen können. Nicht alle Verweisungen in diesen Literaturhinweisen werden im Text der Norm erwähnt. Die Verweisungen wurden je nach Quelle in unterschiedliche Kategorien zusammengefasst.

Verweisungen auf andere Teile der Normenreihe IEC 62443, sowohl auf veröffentlichte als auch auf zukünftige:

- [1] IEC TS 62443-1-1, *Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models*
- [2] IEC TR 62443-1-2⁵, *Security for industrial automation and control systems – Part 1-2: Master glossary of terms and abbreviations*
- [3] IEC TS 62443-1-3⁶, *Security for industrial automation and control systems – Part 1-3: System security compliance metrics*
- [4] IEC TR 62443-1-4⁷, *Security for industrial automation and control systems – Part 1-4: IACS security life-cycle and use-cases*
- [5] IEC 62443-2-1, *Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program*
- [6] IEC TR 62443-2-2⁸, *Security for industrial automation and control systems – Part 2-2: Implementation guidance for an IACS security management system*
- [7] IEC TR 62443-2-3, *Security for industrial automation and control systems – Part 2-3: Patch management in the IACS environment*
- [8] IEC TR 62443-3-1:2009, *Industrial communication networks – Network and system security – Part 3-1: Security technologies for industrial automation and control systems*
- [9] IEC 62443-3-2⁹, *Security for industrial automation and control systems – Part 3-2: Security risk assessment and system design*
- [10] IEC 62443-3-3, *Industrial communication networks – Network and system security – Part 3-3: System security requirements and security levels*
- [11] IEC 62443-4-2¹⁰, *Security for industrial automation and control systems – Part 4-2: Technical security requirements for IACS components*

⁵ In Beratung.

⁶ In Beratung.

⁷ In Beratung.

⁸ In Beratung.

⁹ Derzeit in Vorbereitung. Stufe zum Zeitpunkt der Veröffentlichung: IEC/CDV 62443-3-2:2017.

¹⁰ Derzeit in Vorbereitung. Stufe zum Zeitpunkt der Veröffentlichung: IEC/CDV 62443-4-2:2017.

Weitere Verweisnormen:

[12] ISO/IEC Directives, Part 2, *Principles and rules for the structure and drafting of ISO and IEC documents*

[13] ISO 9001, *Quality management systems – Requirements*

ANMERKUNG Harmonisiert als EN ISO 9001.

[14] ISO/IEC 10746-1, *Information technology – Open distributed processing – Reference model: Overview*

[15] ISO/IEC 10746-2, *Information technology – Open distributed processing – Reference model: Foundations*

[16] ISO/IEC 15408-1, *Information technology – Security techniques – Evaluation criteria for IT security – Part 1: Introduction and general model*

[17] ISO/IEC 15408-2, *Information technology – Security techniques – Evaluation criteria for IT security – Part 2: Security functional components*

[18] ISO/IEC 15408-3, *Information technology – Security techniques – Evaluation criteria for IT security – Part 3: Security assurance components*

[19] ISO/IEC 27002, *Information technology – Security techniques – Code of practice for information security controls*

ANMERKUNG Harmonisiert als EN ISO/IEC 27002.

[20] ISO/IEC 27001, *Information technology – Security techniques – Information security management systems – Requirements*

ANMERKUNG Harmonisiert als EN ISO/IEC 27001.

[21] ISO/IEC 27036-3, *Information technology – Security techniques – Information security for supplier relationships – Part 3: Guidelines for information and communication technology supply chain security*

[22] ISO/IEC 29147, *Information technology – Security techniques – Vulnerability disclosure*

[23] ISO/IEC 30111, *Information technology – Security techniques – Vulnerability handling processes*

[24] IEC 61508 (all parts), *Functional safety of electrical/electronic/programmable electronic safety-related systems*

ANMERKUNG Harmonisiert in der Reihe EN 61508.

[25] IEC 62740, *Root cause analysis (RCA)*

ANMERKUNG Harmonisiert als EN 62740.

[26] ISCI SDLA-300, *Security Development Life-cycle Assurance – Certification Requirement, Version 1, Revision 3*

[27] ISCI EDSA-312, *Embedded Device Security Assurance – Certification Requirements Specifications – Software Development Security Assessment*

[28] ISCI EDSA-310, *Embedded Device Security Assurance – Certification Requirements Specifications – Requirements for embedded device robustness testing, Version 2.2DO-178B, Software Considerations in Airborne Systems and Equipment Certification*

DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10 **EN IEC 62443-4-1:2018**

- [29] NIST Special Publication 800-30, *Guide for Conducting Risk Assessments*
- [30] NIST Special Publication 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems*
- [31] NIST Special Publication 800-55, *Performance Measurement Guide for Information Security*
- [32] NIST Special Publication 800-61, *Computer Security Incident Handling Guide*
- [33] NIST Special Publication 800-82, *Guide to Industrial Control System (ICS) Security*
- [34] NIST Process Control Security Requirements Forum (PCSRF) and the Future of Industrial Control System Security
- [35] ISO/IEC 27034 (alle Teile), *Information technology – Security techniques – Application security*

Branchen- und sektorspezifische Verweisungen:

- [36] OWASP Comprehensive, Lightweight Application Security Process (CLASP), available at <http://www.owasp.org/index.php/Category:OWASP_CLASP_Project> [viewed 2017-08-17]
- [37] Report on the Evaluation of Cybersecurity Self-assessment Tools and Methods, November 2004, ChemITC, available at <<http://www.chemicalcybersecurity.org/>> [viewed 2017-08-17]
- [38] U.S. Chemicals Sector Cyber Security Strategy, September 2006, available at <<http://www.chemicalcybersecurity.org/>> [viewed 2017-08-17]
- [39] Building Security In Maturity Model, September 2011, Gary McGraw, Ph.D., Brian Chess, Ph.D., & Sammy Miguez, available at <<http://www.bsimm.com/>> [viewed 2017-08-17]

Weitere Dokumente und veröffentlichte Publikationen:

- [40] CARLSON, Tom, Information Security Management: Understanding ISO 17799, 2001
- [41] Carnegie Mellon Software Engineering Institute, CMMI for Systems Engineering/Software Engineering/Integrated Product and Process Development/Supplier Sourcing, Version 1.1, Staged Representation, 2002, CMU/SEI-2002-TR-012
- [42] Carnegie Mellon Software Engineering Institute, CMMI for Development (CMMI-DEV), Version 1.3, 2010, CMU/SEI-2010-TR-033

Bücher:

- [43] HOWARD, Michael and LIPNER, Steve, The Security Development Life-cycle; SDL A Process for Developing Demonstrably More Secure Software, 2006, Microsoft Press, Redmond, Washington
- [44] MCGRAW, Gary, Software Security Building Security In, 2006, Addison-Wesley, Upper Saddle River, NJ

Anhang ZA
(normativ)**Normative Verweisungen auf internationale Publikationen
mit ihren entsprechenden europäischen Publikationen**

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

ANMERKUNG 1 Ist eine internationale Publikation durch gemeinsame Abänderungen modifiziert worden, gekennzeichnet durch (mod.), dann gilt die entsprechende EN oder das HD.

ANMERKUNG 2 Aktualisierte Informationen über die in diesem Anhang aufgelisteten aktuellen Fassungen der Europäischen Normen sind hier verfügbar: www.cenelec.eu

<u>Publikation</u>	<u>Jahr</u>	<u>Titel</u>	<u>EN/HD</u>	<u>Jahr</u>
IEC 62443-2-4	2015	Security for industrial process measurement and control – Network and system security – Part 2-4: Certification of IACS supplier security policies and practices	–	–
+ A1	2017		–	–